

The Practitioner's Blueprint for Secure AI

By John M. Willis, Quantum Powered Security, Inc.



August 2025

Copyright and License

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc.

This manuscript is licensed under the Creative Commons Attribution 4.0 International License (CC BY 4.0). You are free to share and adapt this work for any purpose, including commercial use, provided appropriate attribution is given.

License: <https://creativecommons.org/licenses/by/4.0/>

Patent Notice

The concepts, architectures, and reference designs presented in this work are intended to encourage adoption, adaptation, and further innovation. Readers are encouraged to tailor PBSAI to their own environments, products, and services. Novel implementations, extensions, and improvements developed by others may be eligible for intellectual property protection under applicable patent laws.

The authors likewise reserve all rights to pursue patent protection for their own inventions, implementations, improvements, and future developments related to PBSAI. Certain aspects of this work are the subject of pending patent applications. Except as expressly stated by applicable law, no patent rights are granted or implied by this publication or its CC BY 4.0 license.

Volume 2: The Multi-Agent AI Defensive Cybersecurity Ecosystem

Domain F – Data Security & Privacy

Table of Contents

Domain F - Data Security & Privacy	4
F1. Data Discovery Agent	4
Agent Blueprint [Informative]	4
Technical Implementation Details (F1) [Informative]	20
MCP-Native Protocol Specification (F1) [Normative]	22
F2. DLP Monitor Agent	23
Agent Blueprint [Informative]	23
Technical Implementation Details (F2) [Informative]	36
MCP-Native Protocol Specification (F2) [Normative]	38
F3. Crypto Enforcement Agent	38
Agent Blueprint [Informative]	38
Technical Implementation Details (F3) [Informative]	50
MCP-Native Protocol Specification (F3) [Normative]	53
F4. Secure Wipe Agent	53
Agent Blueprint [Informative]	53
Technical Implementation Details (F4) [Informative]	65
MCP-Native Protocol Specification (F4) [Normative]	67
F5. Integrity Monitor Agent	68
Agent Blueprint [Informative]	68
Technical Implementation Details (F5) [Informative]	79
MCP-Native Protocol Specification (F5) [Normative]	81
F6. Privacy Enforcement Agent	82
Agent Blueprint [Informative]	82
Technical Implementation Details (F6) [Informative]	94
MCP-Native Protocol Specification (F6) [Normative]	96

Domain F - Data Security & Privacy

F1. Data Discovery Agent

Agent Blueprint [Informative]

Purpose: Locate and classify sensitive data at rest and in motion across enterprise repositories; emit **DataAssetRecord** and **ClassificationTag** for downstream policy enforcement.

Operational Narrative [Informative]

Inputs used (authoritative sources):

- **File Shares (SMB/NFS):** file walks, metadata, byte previews (hashed), ACL summaries.
- **Databases (JDBC/ODBC/REST):** information schema introspection, column fingerprints, bounded sampling under DQ quotas.
- **Cloud Object Storage (S3/GCS/Azure Blob):** object listings, tags/metadata, server-side encryption posture.
- **Network Flows (NetFlow/IPFIX/Zeek metadata):** app identification, TLS SNI, byte/packet counts to infer data-in-motion usage.

Model training / knowledge (what the LLM relies on):

- Style/policy prompt pack for data handling, classification rubric (NIST 800-60 info types; PII/PHI/PCI dictionaries; business taxonomies).
- RAG sources (enterprise data dictionary, lineage catalog, prior classification decisions, steward glossary). Do **not** train on raw regulated data; fetch via evidence_refs.
- Guardrails (no raw content exfiltration; sample_rows limits; scope-restricted connectors; allow/deny paths, buckets, schemas).

Decisions it makes (deterministic + model-assisted):

- **Asset identity and lineage:** dataset keys, owners, custodians, upstream/downstream links.
- **Sensitivity classification:** Public | Internal | Confidential | Restricted based on signals (schema names, column patterns, preview hashes, flow labels) and prior steward labels.
- **Policy bindings:** which handling policies to attach (encrypt_at_rest, tokenize_on_export, mask_in_nonprod, no_public_acl).

- **Confidence and escalation:** decide when to auto-tag, when to require HITL, and when to open a PolicyDispute.

Routing / where outputs go:

- **DataAssetRecord** → CMDB/Graph API (create/update dataset node, lineage edges, owners, controls).
- **ClassificationTag** → Kafka/AMQP (topics for DLP/ETL/Access platforms).
- **Tickets/alerts** → open steward tasks when low confidence, conflicting labels, or legal_hold constraints.

Automation scope vs. manual/HITL:

- Fully automated: file/object enumeration, schema introspection, pattern fingerprinting, baseline classification with high confidence, DataAssetRecord upsert, ClassificationTag emit.
- **HITL required:** classification for Restricted assets with confidence < theta_restricted; cross-region tagging that implies new data sovereignty requirements; overrides that downgrade sensitivity.
- Manual outside agent: enterprise taxonomy changes; steward assignment policy; exception approvals for sampling constraints.

Security Domain: Data Security & Privacy

Inputs (native protocols consumed) [Informative]

1. **File Shares (SMB/NFS)** — file system walks and metadata/content sampling
2. **Databases (JDBC/ODBC/REST)** — schema introspection and sampling under DQ quotas
3. **Cloud Object Storage (S3/GCS/Azure Blob REST)** — object listings, tags, server-side metadata
4. **Network Flows (NetFlow/IPFIX/Zeek)** — data-in-motion observations

Example: Consumed Protocol 1 — File Shares (SMB/NFS) [Informative]

Native payload

```
{
  "share": "\\fs01\\finance",
  "path": "\\fs01\\finance\\invoices\\2025\\q3\\cc_export.csv",
```

```

"size_bytes": 824331,
"owner_sddl": "S-1-5-21-1000-2000-3000-1101",
"acl_summary": ["Domain Users:R", "Finance Team:RW"],
"mtime": "2025-08-15T12:40:22Z",
"sample": {
  "bytes_preview_sha256": "f4e2a7...c1b9",
  "header": "card_number,expiry,cvc,billing_zip"
},
"scanner": "smbwalk/1.9.3"
}
MCP-wrapped payload
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-f1-smb-1111-2222-3333-4444",
    "thread_id": "uuid-fs01-finance-cc_export",
    "task_id": "uuid-a1b2-c3d4-e5f6-7788",
    "role": "DataDiscoveryAgent",
    "intent": "discover",
    "classification_level": "Restricted",
    "policy_bindings": ["encrypt_at_rest", "tokenize_on_export",
"dlp_block_external_email"],
    "policy_refs": ["DATA-HNDL-001", "SC-28", "MP-4"],
    "decision_basis": {
      "evidence_refs": [
        "uri://smb/fs01/finance/invoices/2025/q3/cc_export.csv",
        "sha256:f4e2a7...c1b9"
      ],

```

```

    "confidence": 0.99,
    "classifier": {"pii_cc_v2": "2.3.7"}
  },
  "provenance": {
    "producer_spiffe": "spiffe://enterprise/data/data-discovery-agent",
    "signing_kid": "kid-smb-f1-01",
    "attestation_ref": "uri://slsa/attestations/data-discovery@sha256:smb01"
  },
  "classification": "C2",
  "legal_hold": false,
  "constraints": ["no_raw_content_export:true", "sample_rows<=50"]
},
"native_payload": {
  "share": "\\fs01\\finance",
  "path": "\\fs01\\finance\\invoices\\2025\\q3\\cc_export.csv",
  "size_bytes": 824331,
  "owner_sddl": "S-1-5-21-1000-2000-3000-1101",
  "acl_summary": ["Domain Users:R", "Finance Team:RW"],
  "mtime": "2025-08-15T12:40:22Z",
  "sample": {
    "bytes_preview_sha256": "f4e2a7...c1b9",
    "header": "card_number,expiry,cvc,billing_zip"
  },
  "scanner": "smbwalk/1.9.3"
}
}

```

Example: Consumed Protocol 2 — Databases (JDBC/ODBC/REST) [Informative]
Native payload

```
{
  "engine": "postgresql",
  "connection": "jdbc:postgresql://db01.corp:5432/payments",
  "table": "public.customers",
  "columns": [
    {"name": "customer_id", "data_type": "uuid"},
    {"name": "email", "data_type": "varchar"},
    {"name": "ssn", "data_type": "varchar"},
    {"name": "created_at", "data_type": "timestamp"}
  ],
  "row_count_estimate": 1203341,
  "sample_fingerprints": {
    "email": "pattern:email@domain",
    "ssn": "pattern:###-##-####"
  },
  "scan_ts": "2025-08-15T12:55:00Z"
}
```

MCP-wrapped payload

```
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-f1-db-5555-6666-7777-8888",
    "thread_id": "uuid-db01-payments-public.customers",
    "task_id": "uuid-99aa-bbcc-ddee-ff00",
    "role": "DataDiscoveryAgent",
    "intent": "discover",
    "classification_level": "Confidential",
  }
}
```

```

"policy_bindings": ["mask_in_nonprod", "tokenize_on_export"],
"policy_refs": ["DATA-HNDL-002", "AC-6", "SC-7"],
"decision_basis": {
  "evidence_refs": [
    "uri://jdbc/pg/db01/payments/public.customers",
    "uri://catalog/db01/payments/information_schema"
  ],
  "confidence": 0.97,
  "classifier": {"pii_ssn_v1": "1.4.2", "pii_email_v1": "1.9.0"}
},
"provenance": {
  "producer_spiffe": "spiffe://enterprise/data/data-discovery-agent",
  "signing_kid": "kid-jdbc-f1-02",
  "attestation_ref": "uri://slsa/attestations/data-discovery@sha256:jdbc02"
},
"classification": "C2",
"legal_hold": false,
"constraints": ["sample_rows<=100", "no_raw_content_export:true"]
},
"native_payload": {
  "engine": "postgresql",
  "connection": "jdbc:postgresql://db01.corp:5432/payments",
  "table": "public.customers",
  "columns": [
    {"name": "customer_id", "data_type": "uuid"},
    {"name": "email", "data_type": "varchar"},
    {"name": "ssn", "data_type": "varchar"},

```

```

    {"name": "created_at", "data_type": "timestamp"}
  ],
  "row_count_estimate": 1203341,
  "sample_fingerprints": {
    "email": "pattern:email@domain",
    "ssn": "pattern:###-##-#####"
  },
  "scan_ts": "2025-08-15T12:55:00Z"
}
}

```

Example: Consumed Protocol 3 — Cloud Object Storage (S3/GCS/Azure Blob)
 [Informative]
 Native payload

```

{
  "bucket": "pii-archive-us-east-1",
  "key": "exports/2025/08/customers_2025-08-14.parquet",
  "size_bytes": 50433112,
  "etag": "b1d2...7fa9",
  "last_modified": "2025-08-15T01:12:33Z",
  "sse": {"algorithm": "aws:kms", "kms_key_id": "arn:aws:kms:us-east-1:111122223333:key/abcd-1234"},
  "tags": {"owner": "payments", "retention": "1y"}
}

```

MCP-wrapped payload

```

{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-f1-s3-aaaa-bbbb-cccc-dddd",

```

```
"thread_id": "uuid-bucket-pii-archive-us-east-1",
"task_id": "uuid-1122-3344-5566-7788",
"role": "DataDiscoveryAgent",
"intent": "discover",
"classification_level": "Confidential",
"policy_bindings": ["encrypt_at_rest", "lifecycle_retention_1y", "no_public_acl"],
"policy_refs": ["SC-13", "SC-28", "MP-6"],
"decision_basis": {
  "evidence_refs": ["uri://s3/pii-archive-us-east-1/exports/2025/08/customers_2025-08-14.parquet"],
  "confidence": 0.95,
  "classifier": {"parquet_schema_probe": "0.6.1"}
},
"provenance": {
  "producer_spiffe": "spiffe://enterprise/data/data-discovery-agent",
  "signing_kid": "kid-s3-f1-03",
  "attestation_ref": "uri://slsa/attestations/data-discovery@sha256:s303"
},
"classification": "C2",
"legal_hold": false
},
"native_payload": {
  "bucket": "pii-archive-us-east-1",
  "key": "exports/2025/08/customers_2025-08-14.parquet",
  "size_bytes": 50433112,
  "etag": "b1d2...7fa9",
  "last_modified": "2025-08-15T01:12:33Z",
```

```

    "sse": {"algorithm": "aws:kms", "kms_key_id": "arn:aws:kms:us-east-1:111122223333:key/abcd-1234"},
    "tags": {"owner": "payments", "retention": "1y"}
  }
}

```

Example: Consumed Protocol 4 — Network Flows (NetFlow/IPFIX/Zeek)

[Informative]

Native payload

```

{
  "exporter": "edge-gw-01",
  "flow_start": "2025-08-15T12:10:05Z",
  "flow_end": "2025-08-15T12:10:35Z",
  "src_ip": "10.2.14.5",
  "dst_ip": "198.51.100.77",
  "src_port": 44322,
  "dst_port": 443,
  "protocol": 6,
  "bytes": 8442132,
  "packets": 5521,
  "app_label": "SaaS_Storage_Dropbox",
  "tls_sni": "content.dropboxapi.com"
}

```

MCP-wrapped payload

```

{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-f1-flow-cccc-dddd-eeee-ffff",
    "thread_id": "uuid-flow-10.2.14.5-198.51.100.77-2025-08-15T12:10",

```

```
"task_id": "uuid-7788-8899-99aa-aabb",
"role": "DataDiscoveryAgent",
"intent": "discover",
"classification_level": "Confidential",
"policy_bindings": ["dlp_monitor", "egress_allow_only_approved_saas"],
"policy_refs": ["SC-7", "SI-4", "DATA-HNDL-003"],
"decision_basis": {
  "evidence_refs": ["uri://ipfix/edge-gw-01/flows/2025-08-15T12:10:05Z-12:10:35Z"],
  "confidence": 0.9,
  "classifier": {"appid": "ndpi-4.4.0", "sni_probe": "1.2.0"}
},
"provenance": {
  "producer_spiffe": "spiffe://enterprise/data/data-discovery-agent",
  "signing_kid": "kid-ipfix-f1-04",
  "attestation_ref": "uri://slsa/attestations/data-discovery@sha256:ipfix04"
},
"classification": "C1",
"legal_hold": false,
"constraints": ["no_packet_payload_capture:true"]
},
"native_payload": {
  "exporter": "edge-gw-01",
  "flow_start": "2025-08-15T12:10:05Z",
  "flow_end": "2025-08-15T12:10:35Z",
  "src_ip": "10.2.14.5",
  "dst_ip": "198.51.100.77",
  "src_port": 44322,
```

```

"dst_port": 443,
"protocol": 6,
"bytes": 8442132,
"packets": 5521,
"app_label": "SaaS_Storage_Dropbox",
"tls_sni": "content.dropboxapi.com"
}
}

```

Outputs (native) [Informative]

- **CMDB/Graph REST DataAssetRecord** (dataset node with lineage, owners).
- **Kafka/AMQP ClassificationTag** (e.g., PCI, PHI, PII_SSN, Confidential).

MCP context (required) [Informative]

mission_id; role="DataDiscoveryAgent"; intent="discover"; classification_level;
policy_bindings; provenance (SPIFFE ID, signing KID, attestation)

MCP context (optional) [Informative]

policy_refs; decision_basis (evidence refs, confidence, classifier version); legal_hold;
constraints (sample_rows, no_raw_content_export)

Enforcement note [Informative]

PEPs and downstream DLP/ETL controllers must enforce **policy_bindings** associated to emitted assets/tags; sampling constraints must be honored (no raw content export).

NIST SP 800-160v2 linkage [Informative]

Establish Context; Implement & Evaluate — identify information assets and apply protection strategies based on risk.

Automation feasibility [Informative]

High (discovery and tagging are automatable; policy exceptions and sovereignty changes may require HITL).

Output Contracts (merged) [Informative]

(OC-1/OC-2 are primary; OC-3..OC-6 are enterprise extensions if adopted.)

OC-1: DataAssetRecord (CMDB/Graph Upsert) [Informative]

- **Producer(s):** F1
- **Topic/Path:** POST /api/graph/datasets and PATCH /api/graph/datasets/{id}
- **Schema/Format:** DataAssetRecord@1.0 (dataset identity, owners, lineage, controls)
- **Classification:** C1 (metadata only) unless includes sensitive lineage → C2
- **Delivery:** at-least-once
- **Ordering:** per-asset-id
- **Idempotency-Key:** sha256(asset_fqn, source_system, snapshot_ts_floor_1h)
- **Ack/Nack:** 201/200 is ACK; 4xx/5xx is NACK
- **Timeouts/Retry:** ack<=30s; exp-backoff<=5x; dead-letter to cmdb.repair
- **Side-Effects:** create/update lineage edges; attach policy_bindings; steward assignment
- **HITL Token:** required when updating **Restricted** asset owners or cross-region lineage
- **Observability:** trace_id, mission_id, asset_fqn, classification_level, evidence_refs, provenance.attestation
- **Retention/TTL:** 7 years (audit metadata)

Schema Capsule (OC-1) [Normative]

Requirement Level: Required

Condition: Always

schema_id=DataAssetRecord@1.0 | json_schema_uri=uri://schema/data-asset-record-1.0.json | sha256= | producers=F1 | consumers=CMDB-01, Lineage-01 | accepts=1.0–1.x

Conformance: This capsule and the corresponding MCP schema define testable requirements.

OC-2: ClassificationTag (Event for Enforcement) [Informative]

- **Producer(s):** F1
- **Topic/Path:** Kafka sec.data.classification, AMQP sec.data.tag
- **Schema/Format:** ClassificationTag@1.0 (asset_fqn, tags[], policy_bindings[], confidence)

- **Classification:** C1
- **Delivery:** exactly-once (producer idempotency + consumer enforcement)
- **Ordering:** per-asset-fqn
- **Idempotency-Key:** sha256(asset_fqn, tag_set_sha1, window_24h)
- **Ack/Nack:** broker ACKs; on NACK/timeout, retry exp-backoff<=5x
- **Side-Effects:** trigger DLP/ETL policy updates; notify access governance
- **HITL Token:** required when downgrading tags on Restricted assets
- **Observability:** trace_id, mission_id, asset_fqn, tag_set, confidence, decision_basis.classifier
- **Retention/TTL:** 2 years (event log)

Schema Capsule (OC-2) [Normative]

Requirement Level: Conditionally Required

Condition: When real-time enforcement via DLP/ETL or access gateways is present
 schema_id=ClassificationTag@1.0 | json_schema_uri=uri://schema/classification-tag-1.0.json | sha256= | producers=F1 | consumers=DLP-01, ETL-01, AccessGov-01 | accepts=1.0–1.x

Conformance: Normative when condition is met.

OC-3: PolicyDispute (Explainability and Contestability) [Informative, optional]

- **Producer(s):** F1, DataSteward-Portal
- **Topic/Path:** sec.data.contestation
- **Schema/Format:** PolicyDispute@1.0
- **Classification:** C2+
- **Delivery/Ordering:** at-least-once; per-asset-id
- **Idempotency-Key:** sha256(asset_fqn, dispute_id)
- **Ack/Nack:** case_id<=30s else retry/backoff
- **Side-Effects:** freeze downgrades; route to stewards/legal
- **HITL Token:** required for disputes on Restricted assets
- **Observability:** trace_id, mission_id, decision_rationale_url
- **Retention/TTL:** 7 years

Schema Capsule (OC-3) [Normative]

Requirement Level: Optional

Condition: When contestability is enabled

schema_id=PolicyDispute@1.0 | json_schema_uri=uri://schema/policy-dispute-1.0.json

OC-4: IRPolicyViolationEvent (Incident Response Integration) [Informative, optional]

- **Producer(s):** F1
- **Topic/Path:** sec.data.incident
- **Schema/Format:** IRPolicyViolationEvent@1.0 (e.g., Restricted data observed to unapproved SaaS)
- **Classification:** C2
- **Delivery/Ordering:** at-least-once; per-incident-id
- **Idempotency-Key:** sha256(incident_id, asset_fqn)
- **Ack/Nack:** SIEM/CaseID<=30s; retry/backoff
- **Side-Effects:** open SOAR case; attach flows and evidence_refs
- **Observability:** trace_id, mission_id, incident_id
- **Retention/TTL:** per IR policy (>=1 year)

Schema Capsule (OC-4) [Normative]

Requirement Level: Optional

Condition: When IR/SIEM integration is present

schema_id=IRPolicyViolationEvent@1.0 | json_schema_uri=uri://schema/ir-policy-violation-1.0.json

OC-5: ChangelImpactReport (Classification Drift/Delta) [Informative, optional]

- **Producer(s):** F1
- **Topic/Path:** sec.data.change_impact
- **Schema/Format:** ChangelImpactReport@1.0 (delta of tags/policies for asset_fqn)
- **Classification:** C1
- **Delivery/Ordering:** at-least-once; per-asset-fqn

- **Idempotency-Key:** sha256(asset_fqn, prev_tag_set_sha1, new_tag_set_sha1)
- **Ack/Nack:** posted as PR/comment to catalog; retry/backoff
- **Side-Effects:** gate downstream jobs until acknowledged per threshold
- **Observability:** trace_id, mission_id, change_impact_score
- **Retention/TTL:** 1 year

Schema Capsule (OC-5) [Normative]

Requirement Level: Conditionally Required

Condition: When classification drift scoring is enabled

schema_id=ChangeImpactReport@1.0 | json_schema_uri=uri://schema/change-impact-1.0.json

OC-6: FeedbackIngestionEvent (Steward Feedback Loop) [Informative, optional]

- **Producer(s):** Steward Portal, F1 (aggregation)
- **Topic/Path:** sec.data.feedback
- **Schema/Format:** FeedbackIngestionEvent@1.0
- **Classification:** C1
- **Delivery/Ordering:** at-least-once; per-review-id
- **Idempotency-Key:** sha256(review_id, asset_fqn)
- **Ack/Nack:** feedback_id assigned; retry/backoff
- **Side-Effects:** queue for governance-reviewed model/rubric updates
- **Observability:** trace_id, mission_id, labels={helpful|neutral|harmful}
- **Retention/TTL:** 1 year

Schema Capsule (OC-6) [Normative]

Requirement Level: Optional

Condition: When steward feedback workflow is enabled

schema_id=FeedbackIngestionEvent@1.0 | json_schema_uri=uri://schema/feedback-ingestion-1.0.json

State machine (concise) [Informative]

states = { idle, enumerating, sampling, classifying, emitting_records, throttled, contestation_workflow, failed, closed }

transition(idle -> enumerating) when new scope assigned
 transition(enumerating -> sampling) when targets discovered and constraints satisfied
 transition(sampling -> classifying) when fingerprints ready
 transition(classifying -> emitting_records) when confidence >= theta_auto OR
 steward_label exists
 transition(classifying -> contestation_workflow) when conflicting labels or low confidence
 on Restricted
 transition(* -> throttled) on API rate limit or DQ quota breach
 transition(* -> failed) on validation error or policy violation
 timeout(emitting_records, 60s) -> failed; retry <= 5 with exp backoff
 idempotency_key = sha256(asset_fqn, snapshot_ts_floor_1h)

Output Contracts Summary [Normative]

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-1 DataAssetRecord	Required	Always	Authoritative asset inventory
OC-2 ClassificationTag	Conditionally Required	DLP/ETL/access enforcement present	Real-time policy enforcement
OC-3 PolicyDispute	Optional	Contestability enabled	Governance and arbitration
OC-4 IRPolicyViolationEvent	Optional	IR/SIEM integration present	Incident response integration
OC-5 ChangeImpactReport	Conditionally Required	Classification drift scoring enabled	Risk/change management
OC-6 FeedbackIngestionEvent	Optional	Steward feedback workflow	Continuous improvement

Requirement Level Definitions:

- **Required:** Must be implemented for conformant deployment
- **Conditionally Required:** Must be implemented when trigger condition is met
- **Optional:** May be implemented for enhanced functionality

Policies and HITL gates [Informative]

- **policy_refs:** NIST 800-53 (AC, AU, MP, SC, SI-7), NIST 800-60 info types, NIST 800-122 PII, internal data handling policies.
- **HITL required:** Restricted classification with confidence < theta_restricted; cross-region lineage creation; downgrading Restricted→Confidential.
- **Automatic HITL escalation triggers:** model_confidence < theta_low; classifier_version change with eval_drop >= 1.5 percentage points; stakeholder_disagreement_score >= 0.5.
- **Manual outside agent:** taxonomy changes; sovereign boundary exceptions; litigation-driven sampling exceptions.

SLOs and KPIs [Informative]

- DiscoveryLag_p95 <= 24 h per scope
- FalsePositiveRate_30d <= 2 percent
- StewardReview_Median <= 2 business days for Restricted disputes
- TagPropagation_p95 <= 10 min to DLP/ETL
- CoverageAtRest >= 95 percent of in-scope repositories

Outputs index [Informative]

[OC-1 DataAssetRecord], [OC-2 ClassificationTag], [OC-3 PolicyDispute], [OC-4 IRPolicyViolationEvent], [OC-5 ChangeImpactReport], [OC-6 FeedbackIngestionEvent]

Technical Implementation Details (F1) [Informative]

Model and training profile [Informative]

model_id=data-discovery-text-model; temperature=0.1; max_tokens_out=600
prompt_pack_id=data-classification-v1 (rubric, few-shot patterns, policy mappings)
RAG: sources={data dictionary, lineage catalog, prior decisions, steward glossary};
max_docs=10; min_similarity=0.78; citations required
fine_tuning/adapters: optional on synthetic corpora; **never** on raw regulated data
guardrails: no_raw_content_export=true; sample_rows<=100; connector scope
allowlists

Memory and state [Informative]

working_memory.max_tokens=4k; eviction=recency_then_importance
episodic_memory: per mission_id journal of scans and decisions, ttl=365d
semantic_memory: namespaces=["schemas","datasets","classifiers","owners"];
embeddings=text-embedding-sec-v1; k=8
durable_state_store: event-sourced journal of discovered assets; snapshot nightly
consistency: at-least-once (asset upserts); exactly-once (tags per asset_fqn/window)
idempotency: per Output Contracts

Decision and routing logic [Informative]

classification_level = f(signals, prior_labels, steward_overrides)
signals_score = 0.35*pattern_strength* + 0.25schema_semantics + 0.2*acl_sensitivity* +
0.2historical_flow_risk
change_impact_score = 0.5*(new_tags_minus_old) + 0.3*(policy_binding_delta) +
0.2*(downstream_systems_count)

Model Risk Management [Informative]

continuous_validation: daily goldens + adversarial “fake PII” sets
thresholds: eval_pass_rate >= 99.5 percent → else auto_HITL
red_team_cycle: monthly (e.g., PAN/SSN lookalike tests)
rollback_policy: eval_drop >= 1.5 percentage points for 48 h → revert classifier version;
notify owners

Transparency and Audit Trail (Approver/Auditor UX) [Informative]

decision_rationale_template: who/what/why; evidence_refs; classifier_version; hashes
of previews
UI/API: expose classification_label, provenance.attestation, decision_rationale_url
audit_log_format: JSONL; retention per classification and legal_hold

Incident Response Integration [Informative]

emit IRPolicyViolationEvent (OC-4) for Restricted data observed to unapproved SaaS
(NetFlow/Zeek signals); include asset_fqn and flow evidence_refs

Change Impact Assessment [Informative]

compute change_impact_score; gate downstream ETL or access changes when score
>= threshold; emit OC-5 with diff detail

Stakeholder Feedback Loop [Informative]

emit OC-6 with labels and steward notes; apply through governance review to
prompt_pack or classifier thresholds (no auto-training on regulated data)

Data Sovereignty and Legal Hold [Informative]

enforce region tags; block cross-region lineage without HITL; legal_hold=true → override TTL and freeze downgrades

Interfaces (links only) [Informative]

Consumes: SMB/NFS, JDBC/ODBC/REST, S3/GCS/Azure Blob, NetFlow/IPFIX/Zeek

Produces: OC-1, OC-2 (+ optional OC-3..OC-6)

Safety and abuse prevention [Informative]

kill_switch on sampling constraint breach; sandbox mode for unknown connectors; blast-radius caps on tag downgrades

Testing and validation [Informative]

contract tests for all OCs; offline replay of historical scans; synthetic seeded datasets; drift checks and rollback

Deployment and lifecycle [Informative]

horizontal workers per data domain; backpressure on quota; canary classifier updates; SBOM and attestations; sign outputs

References / Standards [Informative]

NIST SP 800-160 Vol. 2; NIST SP 800-53 (AC, AU, MP, SC, SI-7); NIST SP 800-60; NIST SP 800-122; NIST CSF 2.0; ISO/IEC 27002:2022; CIS Controls v8 (3 & 13)

MCP-Native Protocol Specification (F1) [Normative]

(Canonical schemas and validation live here; keep example payloads synchronized with the Agent Blueprint.)

- **Native Protocol(s) Consumed:** SMB/NFS; JDBC/ODBC/REST; S3/GCS/Azure Blob REST; NetFlow/IPFIX/Zeek
- **Native Protocol(s) Produced:** CMDB/Graph DataAssetRecord; Kafka/AMQP ClassificationTag
- **MCP Context Fields:**
 - **Required:** mission_id; role="DataDiscoveryAgent"; intent="discover"; classification_level; policy_bindings; provenance (SPIFFE ID, signing KID, attestation)

- **Optional:** policy_refs; decision_basis (evidence_refs, confidence, classifier version); legal_hold; constraints (sample_rows, no_raw_content_export)
- **Enforcement Note:** PEPs must enforce policy_bindings tied to emitted assets/tags; sampling constraints must be honored.
- **Versioning and compatibility; producers/consumers registry:** authoritative in the schema registry with accepted ranges and EOL dates.
- **Example payloads:** native and MCP-wrapped (authoritative) as provided above.
- **Transparency hooks:** classification_label, provenance.attestation, decision_rationale_url available to downstream UIs/APIs.

Conformance: This section is **[Normative]** and, together with each **Schema Capsule**, defines testable requirements.

F2. DLP Monitor Agent

Agent Blueprint [Informative]

Purpose: Detect and prevent data exfiltration across endpoints, networks, and cloud apps; correlate to user identity; take **BlockAction** or raise **DLPIncident** with override workflow.

Operational Narrative [Informative]

Inputs used (authoritative sources):

- **Endpoint DLP Sensors (Windows/macOS/Linux):** filesystem, clipboard, print/USB, app channels; content fingerprints and rule hits; host/user context.
- **Network DLP / SWG / CASB Inline:** HTTP(S)/SMTP/FTP/ICAP events; category, destination, detections; block/allow decisions from inline engines.
- **Cloud App DLP (SaaS APIs / CASB API mode):** Drive/SharePoint/Box/Gmail/Exchange events; sharing ACL changes; quarantine outcomes.

Model training / knowledge (what the LLM relies on):

- Policy/rubric prompt pack for DLP classification and enforcement; dictionaries for PII/PHI/PCI; business glossary for sensitive terms.
- RAG sources: rule catalog, exception registry, user risk scores (UEBA), asset tags, prior incidents; do **not** ingest raw content—reference **evidence_refs** only.

- Guardrails: no_raw_content_export:true; rate limits on case enrichment; allowlists of enforcement points; **HITL override** required to lift blocks.

Decisions it makes (deterministic + model-assisted):

- **Incident triage:** decide when detections constitute a **DLPIncident** (correlate across channels; deduplicate bursts).
- **Enforcement:** choose **BlockAction** vs **QuarantineAction** vs **Monitor** based on content sensitivity, channel risk, user/asset risk, and policy.
- **Override routing:** determine if override is eligible (business justification, user role, confidence) → open contestation (PolicyDispute) and require approver tokens.
- **Escalation/Legal hold:** auto-set legal_hold=true for high-severity or regulated content incidents.

Routing / where outputs go:

- **DLPIncident** → Kafka/AMQP topics for SIEM/SOAR; open or enrich cases.
- **EnforcementAction** (Block/Quarantine/Release) → REST/gRPC calls to EDR, SWG, CASB, IdP; append audit journal.
- **Tickets/alerts** → Service desk or approver queues for override requests; steward/owner notifications.

Automation scope vs. manual/HITL:

- Fully automated: sensor ingestion, correlation, baseline blocking/quarantine per rules, incident creation, case enrichment.
- **HITL required:** any override to lift a block/quarantine (**must** include approver token); cross-tenant external sharing exceptions; release of quarantined items with low classifier confidence.
- Manual outside agent: rule authoring/approval; regulatory exception policy; long-term user coaching.

Security Domain: Data Security & Privacy

Inputs (native protocols consumed) [Informative]

1. **Endpoint DLP Sensors (host channels)** — filesystem, clipboard, print/USB, app channels

2. **Network DLP / SWG / CASB Inline (ICAP/Proxy/SMTP)** —
HTTP(S)/SMTP/FTP events
3. **Cloud App DLP (SaaS APIs / CASB API mode)** —
Drive/SharePoint/Box/Gmail/Exchange events

Example: Consumed Protocol 1 — Endpoint DLP Sensors [Informative]
Native payload

```
{  
  "event_id": "edlp-evt-9012",  
  "device_id": "dev-3f91",  
  "user": "E102993",  
  "channel": "usb_write",  
  "file_path": "C:\\Users\\april\\Desktop\\customers_ssn.csv",  
  "content_fingerprints": ["pii_ssn_v1"],  
  "matches": {"ssn_count": 243},  
  "action_taken": "block",  
  "hash_sha256": "7d1b59...8ce2",  
  "timestamp": "2025-08-15T14:02:11Z",  
  "app": "explorer.exe",  
  "rule_id": "DLP-PII-SSN-USB"  
}
```

MCP-wrapped payload

```
{  
  "mcp_context": {  
    "mcp_version": "0.9",  
    "mission_id": "uuid-f2-endpoint-1111-2222-3333-4444",  
    "thread_id": "uuid-edlp-ev-edlp-evt-9012",  
    "task_id": "uuid-a1b2-c3d4-e5f6-7788",  
    "role": "DLPMonitorAgent",  
  }  
}
```

```

"intent": "monitor",
"constraints": ["hitl_required_for_override:true", "quarantine_on_repeat:true"],
"policy_refs": ["AC-4", "SI-4", "MP-5"],
"decision_basis": {
  "evidence_refs": [
    "uri://edlp/events/edlp-evt-9012",
    "sha256:7d1b59...8ce2",
    "rule://dlp/DLP-PII-SSN-USB"
  ],
  "confidence": 0.98,
  "explanation_ref": "uri://kb/dlp/patterns/pii_ssn_v1"
},
"subject_ref": "idp://users/E102993",
"provenance": {
  "producer_spiffe": "spiffe://enterprise/data/dlp-monitor-agent",
  "signing_kid": "kid-edlp-f2-01",
  "attestation_ref": "uri://slsa/attestations/dlp-monitor@sha256:edlp01"
},
"classification": "C3",
"legal_hold": false
},
"native_payload": { ... }
}

```

Example: Consumed Protocol 2 — Network DLP / SWG / CASB Inline [Informative]
Native payload

```

{
  "session_id": "swg-sess-44ac",
  "user": "E102993",

```

```
"src_ip": "10.2.14.5",
"dst_fqdn": "content.dropboxapi.com",
"method": "POST",
"bytes_out": 8123456,
"category": "File Storage",
"rule_id": "DLP-PCI-OUTBOUND",
"detections": ["pci_primary_account_number"],
"action_taken": "block",
"timestamp": "2025-08-15T14:05:20Z"
}
```

MCP-wrapped payload

```
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-f2-swg-5555-6666-7777-8888",
    "thread_id": "uuid-swg-sess-swg-sess-44ac",
    "task_id": "uuid-99aa-bbcc-ddee-ff00",
    "role": "DLPMonitorAgent",
    "intent": "monitor",
    "constraints": ["hitl_required_for_override:true", "block_mode:auto"],
    "policy_refs": ["AC-4", "SC-7", "SI-4"],
    "decision_basis": {
      "evidence_refs": [
        "uri://swg/sessions/swg-sess-44ac",
        "rule://dlp/DLP-PCI-OUTBOUND"
      ],
      "confidence": 0.96,
    }
  }
}
```

```

    "explanation_ref": "uri://kb/dlp/patterns/pci_pan_v2"
  },
  "subject_ref": "idp://users/E102993",
  "provenance": {
    "producer_spiffe": "spiffe://enterprise/data/dlp-monitor-agent",
    "signing_kid": "kid-swg-f2-02",
    "attestation_ref": "uri://slsa/attestations/dlp-monitor@sha256:swg02"
  },
  "classification": "C3",
  "legal_hold": true
},
"native_payload": { ... }
}

```

Example: Consumed Protocol 3 — Cloud App DLP (SaaS APIs / CASB API mode)

[Informative]

Native payload

```

{
  "event_id": "gdrive-dlp-7731",
  "tenant": "corp.example",
  "user": "april.ng@example.com",
  "app": "Google Drive",
  "resource": {
    "file_id": "1x2y3z",
    "file_name": "Q3_financials.xlsx",
    "sha256": "2c4a1e...bb99",
    "size_bytes": 1234456,
    "sharing_change": {"to": "external", "emails": ["thirdparty@gmail.com"]}
  },
}

```

```

"rule_id": "DLP-FIN-EXTERNAL-SHARE",
"detections": ["pci_pan", "financial_terms_dictionary"],
"action_taken": "quarantine",
"timestamp": "2025-08-15T14:08:12Z"
}
MCP-wrapped payload
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-f2-cloud-aaaa-bbbb-cccc-dddd",
    "thread_id": "uuid-gdrive-dlp-7731",
    "task_id": "uuid-1122-3344-5566-7788",
    "role": "DLPMonitorAgent",
    "intent": "monitor",
    "constraints": ["hitl_required_for_override:true", "expire_quarantine_after_days:7"],
    "policy_refs": ["AC-4", "SI-4", "SC-13"],
    "decision_basis": {
      "evidence_refs": [
        "uri://gdrive/dlp/events/gdrive-dlp-7731",
        "uri://gdrive/files/1x2y3z"
      ],
      "confidence": 0.94,
      "explanation_ref": "uri://kb/dlp/saas/external-share-controls"
    },
    "subject_ref": "idp://users/april.ng@example.com",
    "provenance": {
      "producer_spiffe": "spiffe://enterprise/data/dlp-monitor-agent",

```

```

    "signing_kid": "kid-cloud-f2-03",
    "attestation_ref": "uri://slsa/attestations/dlp-monitor@sha256:cloud03"
  },
  "classification": "C3",
  "legal_hold": false
},
"native_payload": { ... }
}

```

Outputs (native) [Informative]

- **Kafka/AMQP DLPIncident** (severity, rule hit, identities, evidence refs).
- **REST/gRPC EnforcementAction** to EDR/SWG/CASB/IdP (BlockAction or QuarantineAction; optional ReleaseWithOverride).

MCP context (required) [Informative]

mission_id; role="DLPMonitorAgent"; intent="monitor"; constraints **must include** hitl_required_for_override:true; provenance (SPIFFE ID, signing KID, attestation)

MCP context (optional) [Informative]

policy_refs; classification (often C3); decision_basis (evidence refs, confidence, explanation_ref); legal_hold

Enforcement note [Informative]

PEPs (EDR, SWG, CASB, IdP) **must** require a valid **HITL override token** (approver-signed) to execute **ReleaseWithOverride**; all Block/Quarantine actions must carry provenance.attestation and be journaled.

NIST SP 800-160v2 linkage [Informative]

Implement & Maintain — engineer exfiltration resistance and continuous monitoring with authoritative provenance and override governance.

Automation feasibility [Informative]

High (sensor ingestion, correlation, enforcement calls); overrides require HITL.

Output Contracts (merged) [Informative]

OC-1: DLPIncident (Event) [Informative]

- **Producer(s):** F2
- **Topic/Path:** Kafka sec.dlp.incident, AMQP sec.dlp.incident
- **Schema/Format:** DLPIncident@1.0 (subject_ref, detections[], rule_id, severity, evidence_refs[], action_summary, legal_hold)
- **Classification:** C3 (contains sensitive indicators; no raw content)
- **Delivery:** at-least-once
- **Ordering:** per-incident-id
- **Idempotency-Key:** sha256(incident_id)
- **Ack/Nack:** broker ACK; NACK/timeout→retry exp-backoff≤5x
- **Side-Effects:** open SOAR case; attach enrichment refs; notify data stewards
- **HITL Token:** not required to emit
- **Observability:** trace_id, mission_id, subject_ref, detections, severity, provenance.attestation
- **Retention/TTL:** per IR policy (≥ 1 year)

Schema Capsule (OC-1) [Normative]

Requirement Level: Required

Condition: Always

schema_id=DLPIncident@1.0 | json_schema_uri=uri://schema/dlp-incident-1.0.json | sha256= | producers=F2 | consumers=SIEM-01, SOAR-01 | accepts=1.0–1.x

Conformance: This capsule and the corresponding MCP schema define testable requirements.

OC-2: EnforcementAction (Block/Quarantine/Release) [Informative]

- **Producer(s):** F2
- **Topic/Path:** REST POST /enforce (EDR/SWG/CASB/IdP) or gRPC Enforcement.Apply
- **Schema/Format:** EnforcementAction@1.0 { action_id, action_type in {"block","quarantine","release_with_override"}, target_ref, subject_ref, reason, rule_id, expires_at?, override_token? }
- **Classification:** C2+

- **Delivery:** exactly-once per action_id (consumer enforces idempotency)
- **Ordering:** per-action_id
- **Idempotency-Key:** sha256(action_id, target_ref)
- **Ack/Nack:** 2xx ACK<=5s; retry exp-backoff<=5x; escalate to HITL on repeated NACK/timeout
- **Side-Effects:** append immutable record to audit journal; link to SOAR case/incident
- **HITL Token:** required when action_type=="release_with_override"
- **Observability:** trace_id, mission_id, subject_ref, target_ref, policy_refs, decision_basis.confidence, provenance.attestation
- **Retention/TTL:** 7 years (audit)

Schema Capsule (OC-2) [Normative]

Requirement Level: Conditionally Required

Condition: When enforcement points (EDR/SWG/CASB/IdP) are enabled or policy mandates blocking/quarantine

schema_id=EnforcementAction@1.0 | json_schema_uri=uri://schema/enforcement-action-1.0.json | sha256= | producers=F2 | consumers=EDR-PEP-01, SWG-PEP-01, CASB-PEP-01, IdP-PEP-01 | accepts=1.0–1.x

Conformance: Normative when condition is met.

OC-3: PolicyDispute (Override/Appeals) [Informative, optional]

- **Producer(s):** F2, Approver Portal
- **Topic/Path:** sec.dlp.contestation
- **Schema/Format:** PolicyDispute@1.0 (incident_id, business_justification, approver_chain, decision_rationale_url)
- **Classification:** C2+
- **Delivery:** at-least-once; per-incident-id
- **Idempotency-Key:** sha256(incident_id, dispute_id)
- **Ack/Nack:** case_id<=30s else retry/backoff
- **Side-Effects:** freeze release unless approver token valid
- **HITL Token:** required to approve release

- **Observability:** trace_id, mission_id, subject_ref, approver_ids

Schema Capsule (OC-3) [Normative]

Requirement Level: Optional

Condition: When contestability/override workflow is enabled

schema_id=PolicyDispute@1.0 | json_schema_uri=uri://schema/policy-dispute-1.0.json

OC-4: IRPolicyViolationEvent (Incident Response Integration) [Informative, optional]

- **Producer(s):** F2
- **Topic/Path:** sec.dlp.ir_event
- **Schema/Format:** IRPolicyViolationEvent@1.0 (mapping to SIEM taxonomy)
- **Classification:** C2
- **Delivery:** at-least-once; per-incident-id
- **Idempotency-Key:** sha256(incident_id, reason_code)

Schema Capsule (OC-4) [Normative]

Requirement Level: Optional

Condition: When IR/SIEM integration is present

schema_id=IRPolicyViolationEvent@1.0 | json_schema_uri=uri://schema/ir-policy-violation-1.0.json

OC-5: ChangelImpactReport (Rule/Policy Drift & Tuning) [Informative, optional]

- **Producer(s):** F2
- **Topic/Path:** sec.dlp.change_impact
- **Schema/Format:** ChangelImpactReport@1.0 (delta of rule/policy impact: false_block_rate, user cohorts affected)
- **Classification:** C1
- **Delivery:** at-least-once; per-rule-id

Schema Capsule (OC-5) [Normative]

Requirement Level: Conditionally Required

Condition: When DLP tuning and drift scoring is enabled

schema_id=ChangelImpactReport@1.0 | json_schema_uri=uri://schema/change-impact-1.0.json

OC-6: FeedbackIngestionEvent (Reviewer Feedback Loop) [Informative, optional]

- **Producer(s):** Reviewer Portal; F2 (aggregation)
- **Topic/Path:** sec.dlp.feedback
- **Schema/Format:** FeedbackIngestionEvent@1.0 (labels, notes, artifact refs)
- **Classification:** C1

Schema Capsule (OC-6) [Normative]

Requirement Level: Optional

Condition: When reviewer feedback workflow is enabled

schema_id=FeedbackIngestionEvent@1.0 | json_schema_uri=uri://schema/feedback-ingestion-1.0.json

State machine (concise) [Informative]

states = { idle, ingesting, correlating, deciding_enforcement, enforcing, incident_open, contestation_workflow, failed, closed }

transition(idle -> ingesting) when sensor events arrive

transition(ingesting -> correlating) when events share subject_ref/window

transition(correlating -> deciding_enforcement) when aggregated_detections >= threshold

transition(deciding_enforcement -> enforcing) when policy requires block/quarantine

transition(deciding_enforcement -> incident_open) when monitor-only or post-enforcement case created

transition(incident_open -> contestation_workflow) when override requested

transition(* -> failed) on validation error or enforcement NACK>5

timeout(enforcing, 5s) -> failed; retry<=5 with exp backoff

idempotency_key = sha256(action_id, target_ref) for enforcement; sha256(incident_id) for incidents

Output Contracts Summary [Normative]

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-1 DLPIncident	Required	Always	Central incidenting for SIEM/SOAR

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-2 EnforcementAction	Conditionally Required	Enforcement points enabled or blocking policy in effect	Real-time control enforcement
OC-3 PolicyDispute	Optional	Override/appeals workflow enabled	Governance and contestability
OC-4 IRPolicyViolationEvent	Optional	IR/SIEM integration present	Incident response integration
OC-5 ChangeImpactReport	Conditionally Required	DLP tuning/drift scoring enabled	Risk/change management
OC-6 FeedbackIngestionEvent	Optional	Reviewer feedback workflow	Continuous improvement

Requirement Level Definitions:

- **Required:** Must be implemented for conformant deployment
- **Conditionally Required:** Must be implemented when trigger condition is met
- **Optional:** May be implemented for enhanced functionality

Policies and HITL gates [Informative]

- **policy_refs:** AC-4 (information flow), SI-4 (monitoring), SC-7 (boundary), MP-5/MP-6 (media), NIST 800-122 (PII), internal DLP policies.
- **HITL required:** release_with_override actions; downgrading severity from High→Low; external share releases on Restricted assets.
- **Automatic HITL escalation triggers:** model_confidence < theta_low; repeat_offense_count >= N; protected_app=true and channel="email_external".

SLOs and KPIs [Informative]

- DetectionToBlock_p95 <= 5 s
- FalseBlockRate_30d <= 1.0 percent
- OverrideDecision_p95 <= 4 business hours

- IncidentMergeDuplicateRate_30d >= 95 percent
- QuarantineReleaseSLA_p95 <= 1 business day (with valid approver token)

Outputs index [Informative]

[OC-1 DLPIncident], [OC-2 EnforcementAction], [OC-3 PolicyDispute], [OC-4 IRPolicyViolationEvent], [OC-5 ChangeImpactReport], [OC-6 FeedbackIngestionEvent]

Technical Implementation Details (F2) [Informative]

Model and training profile [Informative]

model_id=dlp-monitor-text-model; temperature=0.1; max_tokens_out=600
 prompt_pack_id=dlp-policy-v1 (rule catalog, escalation rubric, few-shot enforcement choices)
 RAG: sources={rule catalog, exception registry, UEBA risk, asset tags, prior incidents};
 max_docs=12; min_similarity=0.78; citations required
 fine_tuning/adapters: optional on synthetic/redacted corpora; never on raw payloads
 guardrails: no_raw_content_export:true; allowlisted enforcement endpoints; per-tenant rate limits

Memory and state [Informative]

working_memory.max_tokens=4k; eviction=recency_then_importance
 episodic_memory: per mission_id journal of detections, actions, overrides; ttl=365d
 semantic_memory: namespaces=["rules","exceptions","identities","assets"];
 embeddings=text-embedding-sec-v1; k=8
 durable_state_store: event-sourced incident/action journal; snapshot per 1h window
 consistency: at-least-once (incidents); exactly-once (enforcement actions)
 idempotency: as per Output Contracts

Decision and routing logic [Informative]

$dlp_risk_score = 0.35content_sensitivity + 0.25channel_risk + 0.2user_risk_score + 0.1repeat_offense_norm + 0.1 \cdot (1 - classifier_uncertainty)$
 if dlp_risk_score >= theta_block then action="block"
 else if dlp_risk_score >= theta_quarantine then action="quarantine"
 else action="monitor"
 override_eligible = (business_justification_present and approver_in_role and dlp_risk_score < theta_no_override)

Model Risk Management [Informative]

continuous_validation: daily goldens + adversarial “fake PII/PCI” tests
 thresholds: eval_pass_rate >= 99.5 percent → else auto_HITL

red_team_cycle: monthly ATT&CK/D3FEND-inspired exfil scenarios
rollback_policy: eval_drop >= 1.5 percentage points for 48 h → revert
classifier/prompt_pack; notify owners

Transparency and Audit Trail (Approver/Auditor UX) [Informative]

decision_rationale_template: subject_ref, what/where/why, detections, rules,
evidence_refs, hashes
UI/API: expose classification_label, provenance.attestation, decision_rationale_url
audit_log_format: JSONL with stable field order; legal_hold controls purge

Incident Response Integration [Informative]

emit OC-1 to SIEM/SOAR; map rule_id to MITRE techniques; attach enforcement
outcomes; open playbooks for user coaching or credential lockdown (via IdP)

Change Impact Assessment [Informative]

compute false_block_rate and user_cohort_impact per rule; emit OC-5 for rules
exceeding thresholds; recommend relax/tighten actions

Stakeholder Feedback Loop [Informative]

emit OC-6 from reviewer portals; labels={helpful|neutral|harmful}; route to governance-
reviewed tuning queue (no auto-training on regulated content)

Data Sovereignty and Legal Hold [Informative]

block cross-region release unless approver token includes sovereignty scope; set
legal_hold=true for regulated content or HR cases

Interfaces (links only) [Informative]

Consumes: Endpoint DLP sensors; SWG/CASB inline; SaaS DLP APIs
Produces: OC-1, OC-2 (+ optional OC-3..OC-6)

Safety and abuse prevention [Informative]

kill_switch on anomalous override rates; sandbox mode for new channels; blast-radius
caps on release_with_override per hour

Testing and validation [Informative]

contract tests for OC-1/OC-2; offline replay of historical incidents; synthetic seeded
PII/PCI corpora; drift checks and rollback

Deployment and lifecycle [Informative]

horizontal workers per channel; backpressure on broker lag; canary enforcement;
SBOM + attestations; sign all outputs

References / Standards [Informative]

NIST SP 800-160 Vol. 2; NIST SP 800-53 Rev. 5 (AC-4, SI-4, SC-7, MP-5/MP-6); NIST SP 800-122; NIST CSF 2.0; ISO/IEC 27002:2022; CIS Controls v8 (13); MITRE ATT&CK/D3FEND

MCP-Native Protocol Specification (F2) [Normative]

(Canonical schemas and validation live here; keep example payloads synchronized with the Agent Blueprint.)

- **Native Protocol(s) Consumed:** Endpoint DLP Sensors; Network DLP/SWG/CASB inline; Cloud App DLP APIs
- **Native Protocol(s) Produced:** Kafka/AMQP **DLPIncident**; REST/gRPC **EnforcementAction** (Block/Quarantine/ReleaseWithOverride)
- **MCP Context Fields:**
 - **Required:** mission_id; role="DLPMonitorAgent"; intent="monitor"; constraints includes hitl_required_for_override:true; provenance (SPIFFE ID, signing KID, attestation)
 - **Optional:** policy_refs; classification (often C3); decision_basis; legal_hold
- **Enforcement Note:** PEPs must verify provenance and require a valid approver **override_token** for any release_with_override.
- **Versioning and compatibility; producers/consumers registry:** authoritative in schema registry; see Schema Capsules for accepted ranges/EOL dates.
- **Example payloads:** native and MCP-wrapped (authoritative) as provided above.
- **Transparency hooks:** classification_label, provenance.attestation, decision_rationale_url exposed to downstream UIs/APIs.

Conformance: This section is **[Normative]** and, together with each **Schema Capsule**, defines testable requirements.

F3. Crypto Enforcement Agent

Agent Blueprint [Informative]

Purpose: Verify and enforce encryption in transit and at rest; watch key usage/state; trigger remediation (policy fixes, cert re-issue, key rotation) and publish compliance status.

Operational Narrative [Informative]

Inputs used (authoritative sources):

- **Config Scans (TLS / At-Rest):** active TLS endpoint probes, cipher/versions, HSTS/OCSP stapling, certificate chain and expiry; storage encryption settings (KMS key, SSE mode, rotation flags).
- **KMS Events:** key usage, last_used_ts, grants/aliases/policy diffs, rotation_due_days, origin (HSM/KMS), module validation status.

Model training / knowledge (what the LLM relies on):

- Prompt pack for crypto baselines aligned to NIST 800-52r2, 800-57, 800-175, FIPS 140-3; organization “crypto baseline” rules.
- RAG sources: certificate inventory, endpoint registry, key catalog (aliases, ARNs), exception register, previous compliance reports.
- Guardrails: never push rotation in business hours unless break-glass; require canary for production; restrict enforcement endpoints to allowlist; honor “no_raw_private_key_material:true”.

Decisions it makes (deterministic + model-assisted):

- **Compliance verdict per asset:** pass/fail/warn with control mappings (SC-8, SC-12, SC-13, SC-28).
- **Remediation planning:** choose **KeyRotationAction** windows, canary scope, and dependency order (cert → listener → client truststores).
- **Policy fixes:** detect and recommend baselines (e.g., min_tls_version >= TLS1.2, forbid RC4/CBC on TLS1.2, require TLS1.3 where supported).
- **Escalation & legal hold:** if key policy drift or unauthorized grant appears, open IR event, set legal_hold for investigation.

Routing / where outputs go:

- **CryptoComplianceReport** → REST/Kafka to compliance CMDB, dashboards, SIEM.
- **KeyRotationAction** → REST/Kafka to PKI/KMS orchestrators and service owners (with canary and rollback plans).
- **Tickets/alerts** → change management for risky rotations; PolicyDispute when owners contest remediation.

Automation scope vs. manual/HITL:

- Fully automated: ingest scans and KMS events, compute verdicts, publish **CryptoComplianceReport**, open change tickets for low-risk rotations.
- **HITL required:** rotations on CrownJewels, cross-account key re-grants, algorithm family changes (e.g., RSA→ECDSA), immediate rotation due to suspected compromise.
- Manual outside agent: crypto baseline updates; vendor TLS feature exceptions; break-glass decisioning during active incidents.

Security Domain: Data Security & Privacy

Inputs (native protocols consumed) [Informative]

1. **Config Scans — TLS / At-Rest** — TLS endpoint scans, storage-at-rest configuration checks
2. **KMS Events** — key usage, rotation/expiry, policy/grant changes

Example: Consumed Protocol 1 — Config Scans (TLS / At-Rest) [Informative]

Native payload

```
{
  "target": "api.payments.example.com:443",
  "scan_ts": "2025-08-15T14:20:05Z",
  "protocols": ["TLS1.2", "TLS1.3"],
  "weak_protocols": [],
  "cipher_suites": {
    "TLS1.2": ["TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384"],
    "TLS1.3": ["TLS_AES_256_GCM_SHA384"]
  },
  "findings": {
    "rc4_present": false,
    "cbc_suites_present": false,
    "ocsp_stapling": true,
    "hsts": true,
  }
}
```

```

"min_tls_version": "TLS1.2",
"cert": {
  "subject": "CN=api.payments.example.com",
  "issuer": "CN=Enterprise-ICA-01",
  "serial": "63AF9C01D2",
  "sig_alg": "sha256WithRSAEncryption",
  "key_type": "RSA",
  "key_bits": 3072,
  "not_after": "2026-02-10T00:00:00Z",
  "san": ["api.payments.example.com"]
},
"scanner": "tlsprobe/2.4.1"
}

```

MCP-wrapped payload

```

{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-f3-tls-1111-2222-3333-4444",
    "thread_id": "uuid-api.payments.example.com-2025-08-15T14:20:05Z",
    "task_id": "uuid-a1b2-c3d4-e5f6-7788",
    "role": "CryptoEnforcementAgent",
    "intent": "enforce",
    "policy_refs": ["SC-8", "SC-13", "ORG-CRYPTO-TLS-2025"],
    "constraints": ["rotation_window:offhours"],
    "key_provenance": {
      "type": "certificate",

```

```

    "issuer": "Enterprise-ICA-01",
    "cert_serial": "63AF9C01D2",
    "hsm_attestation_ref": "uri://pki/hsm/slot3/keyid:api-payments-01"
  },
  "decision_basis": {
    "evidence_refs": ["uri://tlsprobe/results/api.payments.example.com/2025-08-15T14:20:05Z"],
    "confidence": 0.97,
    "explanation_ref": "uri://kb/crypto/tls-min-version-and-cipher-baseline"
  },
  "provenance": {
    "producer_spiffe": "spiffe://enterprise/data/crypto-enforcement-agent",
    "signing_kid": "kid-tls-f3-01",
    "attestation_ref": "uri://slsa/attestations/crypto-enforce@sha256:tls01"
  },
  "classification": "C1",
  "legal_hold": false
},
"native_payload": { ... }
}

```

Example: Consumed Protocol 2 — KMS Events (key usage/state/policy)

[Informative]

Native payload

```

{
  "event_id": "kms-evt-5c92",
  "provider": "aws-kms",
  "region": "us-east-1",
  "timestamp": "2025-08-15T14:25:44Z",

```

```

    "key_arn": "arn:aws:kms:us-east-1:111122223333:key/2fe1f9f7-9e31-4b9f-a7d7-0c6b7a8c5e42",
    "key_state": "Enabled",
    "key_spec": "SYMMETRIC_DEFAULT",
    "origin": "AWS_KMS",
    "grants_changed": false,
    "rotation_due_days": 12,
    "last_used_service": "s3",
    "last_used_ts": "2025-08-15T13:59:01Z",
    "policy_change": {
      "changed": true,
      "diff": ["ALLOW added for role arn:aws:iam::111122223333:role/legacy-backup"]
    }
  }
}

```

MCP-wrapped payload

```

{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-f3-kms-5555-6666-7777-8888",
    "thread_id": "uuid-kms-arn:aws:kms:us-east-1:111122223333:key:2fe1f9f7",
    "task_id": "uuid-99aa-bbcc-ddee-ff00",
    "role": "CryptoEnforcementAgent",
    "intent": "enforce",
    "policy_refs": ["SC-12", "SC-13", "SC-28", "ORG-CRYPTO-KMS-ROTATION-365D"],
    "constraints": ["rotation_window:offhours", "canary_required:true"],
    "key_provenance": {
      "type": "kms",

```

```

    "kms_arn": "arn:aws:kms:us-east-1:111122223333:key/2fe1f9f7-9e31-4b9f-a7d7-0c6b7a8c5e42",
    "origin": "AWS_KMS",
    "fips_module": "FIPS 140-3 validated (provider doc ref)"
  },
  "decision_basis": {
    "evidence_refs": ["uri://kms/events/kms-evt-5c92"],
    "confidence": 0.95,
    "explanation_ref": "uri://kb/crypto/kms-rotation-and-least-privilege"
  },
  "provenance": {
    "producer_spiffe": "spiffe://enterprise/data/crypto-enforcement-agent",
    "signing_kid": "kid-kms-f3-02",
    "attestation_ref": "uri://slsa/attestations/crypto-enforce@sha256:kms02"
  },
  "classification": "C2",
  "legal_hold": false
},
"native_payload": { ... }
}

```

Outputs (native) [Informative]

- **CryptoComplianceReport (REST/Kafka):** asset, controls, pass/fail, findings, evidence refs, remediation summary.
- **KeyRotationAction (REST/Kafka):** target key/cert, rotation window, canary scope, dependency steps, rollback plan, approvals.

MCP context (required) [Informative]

mission_id; role="CryptoEnforcementAgent"; intent="enforce"; policy_refs;
key_provenance; provenance (SPIFFE ID, signing KID, attestation)

MCP context (optional) [Informative]

classification (usually C1–C2); constraints (e.g., rotation_window:offhours, canary_required:true); decision_basis (evidence refs, confidence, explanation_ref); legal_hold

Enforcement note [Informative]

PEPs/orchestrators must verify provenance.attestation on **KeyRotationAction** and enforce canary_required:true for production keys; deny execution without required approvals and windows.

NIST SP 800-160v2 linkage [Informative]

Implement & Maintain — encode crypto protections as resilient design elements and continuously verify.

Automation feasibility [Informative]

High (continuous verification and policy pushes automated; high-risk rotations gated by policy/HITL).

Output Contracts (merged) [Informative]

OC-1: CryptoComplianceReport [Informative]

- **Producer(s):** F3
- **Topic/Path:** REST POST /crypto/compliance, Kafka sec.crypto.compliance
- **Schema/Format:** CryptoComplianceReport@1.0 { asset_id, asset_type, control_mappings[], status in {"pass","fail","warn"}, findings[], evidence_refs[], remediation_plan_ref? }
- **Classification:** C1 (metadata) → C2 if findings reveal sensitive topology
- **Delivery:** at-least-once
- **Ordering:** per-asset_id
- **Idempotency-Key:** sha256(asset_id, snapshot_ts_floor_1h)
- **Ack/Nack:** 2xx or broker ACK; NACK/timeout→retry exp-backoff≤5x
- **Side-Effects:** update compliance dashboard; attach to CMDB asset; notify owners on fail
- **HITL Token:** not required
- **Observability:** trace_id, mission_id, asset_id, status, policy_refs, provenance.attestation

- **Retention/TTL:** 7 years

Schema Capsule (OC-1) [Normative]

Requirement Level: Required

Condition: Always

schema_id=CryptoComplianceReport@1.0 | json_schema_uri=uri://schema/crypto-compliance-report-1.0.json | sha256= | producers=F3 | consumers=CMDB-01, Dash-01, SIEM-01 | accepts=1.0–1.x

Conformance: This capsule and the corresponding MCP schema define testable requirements.

OC-2: KeyRotationAction [Informative]

- **Producer(s):** F3
- **Topic/Path:** REST POST /crypto/rotation or Kafka sec.crypto.rotation
- **Schema/Format:** KeyRotationAction@1.0 { action_id, target_ref (kms_arn|cert_serial), rotation_window, canary_required, dependencies[], rollback_plan_ref, approvals[], expires_at }
- **Classification:** C2
- **Delivery:** exactly-once per action_id
- **Ordering:** per-action_id
- **Idempotency-Key:** sha256(action_id, target_ref)
- **Ack/Nack:** orchestrator ACK<=30s; retry<=5; escalate to HITL on repeated NACK/timeout
- **Side-Effects:** create change ticket; pause dependent deploys until post-verify; append immutable audit record
- **HITL Token:** required for CrownJewels, cross-account, or algorithm family changes
- **Observability:** trace_id, mission_id, target_ref, policy_refs, decision_basis.confidence, provenance.attestation
- **Retention/TTL:** 7 years

Schema Capsule (OC-2) [Normative]

Requirement Level: Conditionally Required

Condition: When rotation_due_days <= threshold or noncompliance requires rotation/cert re-issue

schema_id=KeyRotationAction@1.0 | json_schema_uri=uri://schema/key-rotation-action-1.0.json | sha256= | producers=F3 | consumers=PKI-01, KMS-Orch-01, Change-01 | accepts=1.0–1.x

Conformance: Normative when condition is met.

OC-3: PolicyDispute (Explainability and Contestability) [Informative, optional]

- **Producer(s):** F3, Crypto-Owners Portal
- **Topic/Path:** sec.crypto.contestation
- **Schema/Format:** PolicyDispute@1.0 (asset_id, dispute_reason, business_justification, approver_chain, decision_rationale_url)
- **Classification:** C2+
- **Delivery/Ordering:** at-least-once; per-asset_id
- **Idempotency-Key:** sha256(asset_id, dispute_id)
- **HITL Token:** required to approve defer/waive rotation

Schema Capsule (OC-3) [Normative]

Requirement Level: Optional

Condition: When contestability is enabled

schema_id=PolicyDispute@1.0 | json_schema_uri=uri://schema/policy-dispute-1.0.json

OC-4: IRPolicyViolationEvent (Incident Response Integration) [Informative, optional]

- **Producer(s):** F3
- **Topic/Path:** sec.crypto.ir_event
- **Schema/Format:** IRPolicyViolationEvent@1.0 (e.g., unauthorized grant added; key disabled; TLS downgrade detected)
- **Classification:** C2
- **Delivery/Ordering:** at-least-once; per-incident-id

Schema Capsule (OC-4) [Normative]

Requirement Level: Optional

Condition: When IR/SIEM integration is present

schema_id=IRPolicyViolationEvent@1.0 | json_schema_uri=uri://schema/ir-policy-violation-1.0.json

OC-5: ChangelImpactReport (Crypto Change Management) [Informative, optional]

- **Producer(s):** F3
- **Topic/Path:** sec.crypto.change_impact
- **Schema/Format:** ChangelImpactReport@1.0 (service_count_affected, client_types, mTLS coverage delta, risk_reduction_score)
- **Classification:** C1
- **Delivery/Ordering:** at-least-once; per-change-set

Schema Capsule (OC-5) [Normative]

Requirement Level: Conditionally Required

Condition: When crypto change impact scoring is enabled

schema_id=ChangelImpactReport@1.0 | json_schema_uri=uri://schema/change-impact-1.0.json

OC-6: FeedbackIngestionEvent (Stakeholder Feedback Loop) [Informative, optional]

- **Producer(s):** Service Owner Portal; F3 (aggregation)
- **Topic/Path:** sec.crypto.feedback
- **Schema/Format:** FeedbackIngestionEvent@1.0 (labels, notes, artifact refs)
- **Classification:** C1

Schema Capsule (OC-6) [Normative]

Requirement Level: Optional

Condition: When reviewer feedback workflow is enabled

schema_id=FeedbackIngestionEvent@1.0 | json_schema_uri=uri://schema/feedback-ingestion-1.0.json

State machine (concise) [Informative]

states = { idle, ingesting_scan_events, ingesting_kms_events, evaluating, compliant, noncompliant, plan_rotation, executing_rotation, verifying_postfix, contestation_workflow, failed, closed }

transition(idle -> ingesting_scan_events) when new scan results arrive

transition(idle -> ingesting_kms_events) when KMS event received

transition(ingesting_* -> evaluating) when evidence set complete or timeout

transition(evaluating -> compliant) when all controls pass
 transition(evaluating -> noncompliant) when any control fails
 transition(noncompliant -> plan_rotation) when rotation_due_days <= threshold or cert expiry < threshold
 transition(plan_rotation -> executing_rotation) when approvals met and window open
 transition(executing_rotation -> verifying_postfix) when orchestrator ACK received
 transition(verifying_postfix -> compliant) when re-scan passes
 transition(noncompliant -> contestation_workflow) when PolicyDispute opened
 transition(* -> failed) on validation error or orchestrator NACK>5
 timeout(executing_rotation, 30m) -> failed; retry<=3 with exp backoff
 idempotency_key = sha256(asset_id, snapshot_ts_floor_1h) for reports;
 sha256(action_id, target_ref) for rotations

Output Contracts Summary [Normative]

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-1 CryptoComplianceReport	Required	Always	Authoritative crypto posture
OC-2 KeyRotationAction	Conditionally Required	rotation_due_days <= threshold OR noncompliance requires rotation	Risk reduction via timely rotation
OC-3 PolicyDispute	Optional	Contestability enabled	Governance and arbitration
OC-4 IRPolicyViolationEvent	Optional	IR/SIEM integration present	Incident response integration
OC-5 ChangeImpactReport	Conditionally Required	Crypto change impact scoring enabled	Risk/change management
OC-6 FeedbackIngestionEvent	Optional	Stakeholder feedback workflow enabled	Continuous improvement

Requirement Level Definitions:

- **Required:** Must be implemented for conformant deployment

- **Conditionally Required:** Must be implemented when trigger condition is met
- **Optional:** May be implemented for enhanced functionality

Policies and HITL gates [Informative]

- policy_refs: SC-8, SC-12, SC-13, SC-28; org crypto baseline; FIPS 140-3 validated modules.
- **HITL required:** CrownJewels rotations; cross-account grant revocations; algorithm family changes; immediate rotations during peak hours.
- **Automatic HITL escalation triggers:** model_confidence < theta_low; rotation_due_days <= emergency_threshold; unauthorized grant detected; cert_expiry < 7 days on prod endpoint.

SLOs and KPIs [Informative]

- ComplianceReportEmit_p95 <= 10 min from evidence arrival
- RotationPlanLeadTime_median >= 24 h (non-emergency)
- PostRotationVerification_p95 <= 15 min
- RotationGlitchRate_30d <= 0.5 percent
- CryptoDriftDetect_MTTD <= 24 h

Outputs index [Informative]

[OC-1 CryptoComplianceReport], [OC-2 KeyRotationAction], [OC-3 PolicyDispute], [OC-4 IRPolicyViolationEvent], [OC-5 ChangeImpactReport], [OC-6 FeedbackIngestionEvent]

Technical Implementation Details (F3) [Informative]

Model and training profile [Informative]

model_id=crypto-enforcement-text-model; temperature=0.1; max_tokens_out=600
prompt_pack_id=crypto-baseline-v1 (TLS/KMS baselines, exception rubric, rotation playbooks)

RAG: sources={cert inventory, endpoint registry, key catalog, exception register, prior reports}; max_docs=12; min_similarity=0.78; citations required

fine_tuning/adapters: optional on synthetic configs; never on private keys or raw secrets
guardrails: enforce canary_required:true for prod; deny private key access; allowlist orchestrators

Memory and state [Informative]

working_memory.max_tokens=4k; eviction=recency_then_importance
episodic_memory: per mission_id journal of findings, actions, verifications; ttl=365d
semantic_memory: namespaces=["assets","keys","certs","baselines","exceptions"];
embeddings=text-embedding-sec-v1; k=8
durable_state_store: event-sourced journal; nightly snapshots
consistency: at-least-once (reports); exactly-once (rotation actions)
idempotency: per Output Contracts

Decision and routing logic [Informative]

$\text{crypto_risk_score} = 0.3\text{protocol_gap} + 0.25\text{cipher_weakness} + 0.2\text{cert_expiry_risk} + 0.15\text{kms_policy_drift} + 0.1*\text{data_sensitivity}$

where

$\text{protocol_gap} = 1$ if $\text{min_tls_version} < \text{required_min}$ else 0

$\text{cipher_weakness} = \text{fraction_of_disallowed_ciphers}$

$\text{cert_expiry_risk} = \max(0, 1 - \text{days_to_expiry} / 90)$

$\text{kms_policy_drift} = \text{indicator}(\text{unauthorized_grant or rotation_disabled})$

data_sensitivity in {0.2 for public, 0.6 for internal, 1.0 for restricted}

action selection:

- if $\text{crypto_risk_score} \geq \text{theta_rotate}$ or $\text{rotation_due_days} \leq \text{threshold}$ then plan rotation
- if $\text{crypto_risk_score} \geq \text{theta_fix}$ and rotation not required then emit policy fix tasks and re-scan
- always emit CryptoComplianceReport

Model Risk Management [Informative]

continuous_validation: daily goldens + adversarial “misleading scan” sets

thresholds: $\text{eval_pass_rate} \geq 99.5$ percent → else auto_HITL

red_team_cycle: monthly TLS downgrade and rogue grant simulations

rollback_policy: if $\text{eval_drop} \geq 1.5$ percentage points for 48 h → revert

prompt_pack/model; notify owners

Transparency and Audit Trail (Approver/Auditor UX) [Informative]

decision_rationale_template: asset, controls, evidence_refs, baselines applied, computed risk, chosen action, hashes

UI/API: expose classification_label, provenance.attestation, decision_rationale_url

audit_log_format: JSONL with stable field order; legal_hold extends retention

Incident Response Integration [Informative]

emit IRPolicyViolationEvent (OC-4) on unauthorized grant, disabled rotation, or TLS downgrade; attach KMS/TLS evidence_refs

Change Impact Assessment [Informative]

compute risk_reduction_score and service_count_affected for each rotation plan; emit ChangeImpactReport (OC-5); gate execution if impact exceeds threshold without approvals

Stakeholder Feedback Loop [Informative]

emit FeedbackIngestionEvent (OC-6) from service owners; apply after governance review to baseline rules (no auto-training on secrets)

Data Sovereignty and Legal Hold [Informative]

respect HSM region constraints; forbid cross-region key material movement; set legal_hold=true when rotations tie to investigations

Interfaces (links only) [Informative]

Consumes: Config Scans (TLS/At-Rest); KMS Events
Produces: OC-1, OC-2 (+ optional OC-3..OC-6)

Safety and abuse prevention [Informative]

kill_switch on anomalous rotation volume; sandbox for new orchestrators; blast-radius caps for concurrent rotations

Testing and validation [Informative]

contract tests for OC-1/OC-2; offline replay of scan streams; simulated KMS events; drift checks and rollback

Deployment and lifecycle [Informative]

horizontal workers per asset class; backpressure on orchestrator limits; canary rotations; SBOM + attestations; sign all outputs

References / Standards [Informative]

NIST SP 800-160 Vol. 2; NIST SP 800-52r2; NIST SP 800-57; NIST SP 800-38 series; NIST SP 800-175; FIPS 140-3; NIST SP 800-53 (SC-8, SC-12, SC-13, SC-28); NIST CSF 2.0; ISO/IEC 27002:2022; CIS Controls v8

MCP-Native Protocol Specification (F3) [Normative]

(Canonical schemas and validation live here; keep example payloads synchronized with the Agent Blueprint.)

- **Native Protocol(s) Consumed:** Config Scans (TLS/At-Rest); KMS Events
- **Native Protocol(s) Produced:** CryptoComplianceReport (REST/Kafka); KeyRotationAction (REST/Kafka)
- **MCP Context Fields:**
 - **Required:** mission_id; role="CryptoEnforcementAgent"; intent="enforce"; policy_refs; key_provenance; provenance (SPIFFE ID, signing KID, attestation)
 - **Optional:** classification; constraints; decision_basis; legal_hold
- **Enforcement Note:** Orchestrators must verify provenance.attestation and required approvals; enforce rotation windows and canary before execution.
- **Versioning and compatibility; producers/consumers registry:** authoritative in schema registry; see Schema Capsules for accepted ranges/EOL dates.
- **Example payloads:** authoritative native + MCP-wrapped examples as provided above.
- **Transparency hooks:** classification_label, provenance.attestation, decision_rationale_url available to downstream UIs/APIs.

Conformance: This section is **[Normative]** and, together with each **Schema Capsule**, defines testable requirements.

F4. Secure Wipe Agent

Agent Blueprint [Informative]

Purpose: Execute verifiable, irreversible data/media erasure for devices, volumes, and objects; validate against retention/legal policies; issue tamper-evident **WipeCertificate**.

Operational Narrative [Informative]

Inputs used (authoritative sources):

- **Decommission Orders (ITSM/CMDB):** asset identity (CI), drive inventory, encryption status, approvals, location, due date.
- **Retention Expiry Events (Records Mgmt / Object-Store ILM):** bucket/object, retention policy, object lock mode/dates, legal_hold flags, owner.

Model training / knowledge (what the LLM relies on):

- Prompt pack for **NIST 800-88r1** method selection (Clear/Purge/Destroy) by media type, interface, volatility, and encryption posture; organization retention & sanitization policy; chain-of-custody rubric.
- RAG sources: CMDB asset catalog, ITSM tickets, records policies, KMS catalog (for crypto-erase), facility constraints (jurisdiction, waste handling), prior WipeCertificates.
- Guardrails: legal_hold_check=true must pass before any action; two_person_rule:true on destructive actions; never export raw media content; only call allowlisted wipe/orchestrator endpoints.

Decisions it makes (deterministic + model-assisted):

- **Method selection:** choose **Clear** vs **Purge** vs **Destroy** per NIST 800-88r1 and org policy; prefer **crypto-erase** when at-rest encryption with valid KEK/LUKS key present.
- **Eligibility & gating:** verify retention expiry, legal holds, approvals, chain-of-custody feasibility, facility/jurisdiction constraints.
- **Execution plan:** order of operations (service stop → key invalidate/crypto-erase → sanitize firmware routines → physical destruction, if required), verification steps, evidence capture (telemetry, photos/video hashes), and rollback (if wipe aborted).
- **Exception routing:** emit **WipeException** when holds or constraints block action; open contestation workflow if owner disputes.

Routing / where outputs go:

- **WipeCertificate** → REST/Kafka to CMDB/Records Mgmt/SIEM; attach to CI/dataset records; publish checksums and signer attestations.
- **WipeException** → REST/Kafka to exception queue; open change/records/legal case as required.
- **Tickets/alerts** → ITSM change tasks for physical handling; security/legal notifications when attempted wipe under hold is detected.

Automation scope vs. manual/HITL:

- Fully automated: eligibility evaluation, method selection, crypto-erase orchestration, certificate assembly/signing, evidence hashing & journal append.

- **HITL required:** physical destruction (witnessed, two-person sign-off); chain-of-custody verification when media leaves controlled area; overrides to proceed under urgent incident authority.
- Manual outside agent: third-party destruction logistics; regulatory affidavits beyond automated WipeCertificate.

Security Domain: Data Security & Privacy

Inputs (native protocols consumed) [Informative]

1. **Decommission Orders (ITSM/CMDB REST/Kafka)** — device/dataset scheduled for retirement/repurpose
2. **Retention Expiry Events (Records Mgmt / Object-Store ILM)** — dataset eligible for disposition

Example: Consumed Protocol 1 — Decommission Orders (ITSM/CMDB)

[Informative]

Native payload

```
{
  "ticket_id": "RET-004512",
  "ci_id": "CI-SRV-00192",
  "asset": {
    "type": "server",
    "hostname": "db-arch-02",
    "serial": "SN9F3-11A2",
    "drives": [
      {"slot": "sda", "model": "PM9A3", "capacity_gb": 1920, "interface": "NVMe"},
      {"slot": "sdb", "model": "PM9A3", "capacity_gb": 1920, "interface": "NVMe"}
    ],
    "encryption": {"at_rest": true, "kek": "kms://key/vol-kek-01"}
  },
  "requested_by": "ops.retirement",
  "location": "DC-ASHBURN-01",
}
```

```

"target_state": "retire",
"due_date": "2025-08-31",
"attachments": ["uri://rma/labels/RET-004512.pdf"],
"approvals": [
  {"role": "asset_owner", "user": "payments.sre.lead", "status": "approved"},
  {"role": "security", "user": "sec.governance", "status": "approved"}
]
}

```

MCP-wrapped payload

```

{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-f4-dec-1111-2222-3333-4444",
    "thread_id": "uuid-ticket-RET-004512",
    "task_id": "uuid-a1b2-c3d4-e5f6-7788",
    "role": "SecureWipeAgent",
    "intent": "dispose",
    "policy_refs": ["MP-6", "MP-5", "SC-28", "ORG-RETENTION-2025"],
    "legal_hold_check": true,
    "constraints": [
      "method:NIST800-88:Purge",
      "two_person_rule:true",
      "verify_chain_of_custody:true",
      "crypto_erase_allowed:true",
      "rotation_window:offhours"
    ],
    "decision_basis": {

```

```

    "evidence_refs": [
      "uri://itsm/tickets/RET-004512",
      "uri://cmdb/ci/CI-SRV-00192",
      "kms://key/vol-kek-01"
    ],
    "confidence": 0.97,
    "explanation_ref": "uri://kb/disposition/nist800-88-method-selection#nvme"
  },
  "provenance": {
    "producer_spiffe": "spiffe://enterprise/data/secure-wipe-agent",
    "signing_kid": "kid-itsm-f4-01",
    "attestation_ref": "uri://slsa/attestations/secure-wipe@sha256:itsm01"
  },
  "classification": "C2",
  "legal_hold": false
},
"native_payload": { ... }
}

```

Example: Consumed Protocol 2 — Retention Expiry Events (Records Mgmt / Object-Store ILM) [Informative]

Native payload

```

{
  "event_id": "ilm-evt-22019",
  "system": "aws-s3",
  "bucket": "pii-archive-us-east-1",
  "object_key": "exports/2019/04/customers_2019-04-15.parquet",
  "class": "GLACIER",
  "retention_policy_id": "RET-POL-PII-7Y",

```

```
"retention_expires_on": "2025-08-15",
"legal_hold": false,
"object_lock": {"mode": "GOVERNANCE", "retain_until_date": "2025-08-15"},
"owner": "data.governance"
}
```

MCP-wrapped payload

```
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-f4-ilm-5555-6666-7777-8888",
    "thread_id": "uuid-ilm-evt-22019",
    "task_id": "uuid-99aa-bbcc-ddee-ff00",
    "role": "SecureWipeAgent",
    "intent": "dispose",
    "policy_refs": ["MP-6", "SC-28", "ORG-RETENTION-PII-7Y"],
    "legal_hold_check": true,
    "constraints": [
      "method:NIST800-88:Destroy",
      "verify_chain_of_custody:true",
      "two_person_rule:true",
      "no_public_bucket_policy:true"
    ],
    "decision_basis": {
      "evidence_refs": [
        "uri://s3/events/ilm-evt-22019",
        "uri://s3/object/pii-archive-us-east-1/exports/2019/04/customers_2019-04-15.parquet",
        "uri://records/policies/RET-POL-PII-7Y"
      ]
    }
  }
}
```

```

    ],
    "confidence": 0.95,
    "explanation_ref": "uri://kb/disposition/s3-object-lock-and-retention"
  },
  "provenance": {
    "producer_spiffe": "spiffe://enterprise/data/secure-wipe-agent",
    "signing_kid": "kid-ilm-f4-02",
    "attestation_ref": "uri://slsa/attestations/secure-wipe@sha256:ilm02"
  },
  "classification": "C2",
  "legal_hold": false
},
"native_payload": { ... }
}

```

Outputs (native) [Informative]

- **WipeCertificate (REST/Kafka):** cryptographic proof, method, evidence chain, signers.
- **WipeException (REST/Kafka, optional):** emitted when holds/constraints prevent wipe.

MCP context (required) [Informative]

mission_id; role="SecureWipeAgent"; intent="dispose"; policy_refs;
legal_hold_check=true; provenance (SPIFFE ID, signing KID, attestation)

MCP context (optional) [Informative]

constraints (e.g., method:NIST800-88:Clear|Purge|Destroy, two_person_rule:true, verify_chain_of_custody:true, crypto_erase_allowed:true); classification (usually C2–C3 for device metadata); decision_basis; region; facility_id

Enforcement note [Informative]

Wipe orchestrators/PEPs must **deny** execution unless:

- legal_hold_check=true and no active holds found,

- `two_person_rule:true` has two valid approver signatures for destructive actions,
- `provenance.attestation` is valid and in-policy for the facility/region,
- chain-of-custody capture endpoints are reachable and logging.

NIST SP 800-160v2 linkage [Informative]

Implement & Maintain — assured removal of sensitive data and prevention of recovery through verified sanitization with authoritative provenance.

Automation feasibility [Informative]

High (policy checks, crypto-erase, certificate generation); physical destruction/witness steps require HITL.

Output Contracts (merged) [Informative]

OC-1: WipeCertificate [Informative]

- **Producer(s):** F4
- **Topic/Path:** REST POST `/disposition/wipe-certificate`, Kafka `sec.disposition.wipe_certificate`
- **Schema/Format:** `WipeCertificate@1.0 { certificate_id, asset_ref, dataset_ref?, method in {"Clear","Purge","Destroy","CryptoErase"}, method_detail, start_ts, end_ts, evidence_refs[], custody_chain[], location, facility_id?, region?, legal_hold_snapshot, signers[], provenance.attestation, media_inventory_digest }`
- **Classification:** C2+
- **Delivery:** at-least-once
- **Ordering:** per-asset_ref
- **Idempotency-Key:** `sha256(asset_ref, end_ts_floor_1m, method)`
- **Ack/Nack:** 2xx or broker ACK; retry `exp-backoff<=5x`
- **Side-Effects:** attach to CMDB/records; close decommission task; update risk register
- **HITL Token:** not required to emit (but required upstream for destructive steps)
- **Observability:** `trace_id, mission_id, policy_refs, classification_label, decision_basis.summary_ref, provenance.attestation`
- **Retention/TTL:** 7 years (or per `legal_hold`)

Schema Capsule (OC-1) [Normative]

Requirement Level: Required

Condition: Always

schema_id=WipeCertificate@1.0 | json_schema_uri=uri://schema/wipe-certificate-1.0.json | sha256= | producers=F4 | consumers=CMDB-01, Records-01, SIEM-01 | accepts=1.0–1.x

Conformance: This capsule and the corresponding MCP schema define testable requirements.

OC-2: WipeException [Informative]

- **Producer(s):** F4
- **Topic/Path:** REST POST /disposition/wipe-exception, Kafka
sec.disposition.wipe_exception
- **Schema/Format:** WipeException@1.0 { exception_id, asset_ref|dataset_ref, reason_code in {"legal_hold","policy_violation","custody_unverified","window_closed","facility_blocked"}, details, evidence_refs[], requested_by, approver_chain?, expires_at? }
- **Classification:** C2
- **Delivery:** at-least-once
- **Ordering:** per-asset_ref
- **Idempotency-Key:** sha256(asset_ref, reason_code, snapshot_ts_floor_1h)
- **Ack/Nack:** 2xx ACK or broker ACK; retry/backoff
- **Side-Effects:** open legal/records/security case; pause decommission; notify owners
- **HITL Token:** required to authorize temporary deferral of wipe beyond retention SLA
- **Observability:** trace_id, mission_id, policy_refs, classification_label, provenance.attestation
- **Retention/TTL:** per legal policy (≥ 1 year)

Schema Capsule (OC-2) [Normative]

Requirement Level: Conditionally Required

Condition: When holds/constraints prevent wipe or a deferral is requested

schema_id=WipeException@1.0 | json_schema_uri=uri://schema/wipe-exception-1.0.json | sha256= | producers=F4 | consumers=Records-01, Legal-01, Change-01 |

accepts=1.0–1.x

Conformance: Normative when condition is met.

OC-3: PolicyDispute (Explainability and Contestability) [Informative, optional]

- **Producer(s):** F4, Legal/Records portals
- **Topic/Path:** sec.disposition.contestation
- **Schema/Format:** PolicyDispute@1.0 (asset_ref|dataset_ref, dispute_reason, business_justification, approver_chain, decision_rationale_url)

Schema Capsule (OC-3) [Normative]

Requirement Level: Optional

Condition: When contestability workflow is enabled

schema_id=PolicyDispute@1.0 | json_schema_uri=uri://schema/policy-dispute-1.0.json

OC-4: IRPolicyViolationEvent (Incident Response Integration) [Informative, optional]

- **Producer(s):** F4
- **Topic/Path:** sec.disposition.ir_event
- **Schema/Format:** IRPolicyViolationEvent@1.0 (attempted_wipe_under_hold, custody_break, orchestrator_anomaly)

Schema Capsule (OC-4) [Normative]

Requirement Level: Optional

Condition: When IR/SIEM integration is present

schema_id=IRPolicyViolationEvent@1.0 | json_schema_uri=uri://schema/ir-policy-violation-1.0.json

OC-5: ChangeImpactReport (Disposition Program Metrics) [Informative, optional]

- **Producer(s):** F4
- **Topic/Path:** sec.disposition.change_impact
- **Schema/Format:** ChangeImpactReport@1.0 (assets_processed, methods_breakdown, crypto_erase_ratio, exceptions_by_reason, environmental_disposal_queue)

Schema Capsule (OC-5) [Normative]

Requirement Level: Conditionally Required

Condition: When program-level impact/tuning is enabled

schema_id=ChangeImpactReport@1.0 | json_schema_uri=uri://schema/change-impact-1.0.json

OC-6: FeedbackIngestionEvent (Stakeholder Feedback Loop) [Informative, optional]

- **Producer(s):** Records/Facilities portals; F4 (aggregation)
- **Topic/Path:** sec.disposition.feedback
- **Schema/Format:** FeedbackIngestionEvent@1.0 (labels, notes, artifact_refs)

Schema Capsule (OC-6) [Normative]

Requirement Level: Optional

Condition: When reviewer feedback workflow is enabled

schema_id=FeedbackIngestionEvent@1.0 | json_schema_uri=uri://schema/feedback-ingestion-1.0.json

State machine (concise) [Informative]

states = { idle, evaluating_eligibility, planning, executing_clear, executing_purge, executing_destroy, crypto_erase, verifying, issuing_certificate, contestation_workflow, exception_open, failed, closed }

transition(idle -> evaluating_eligibility) when decommission order or retention event ingested

transition(evaluating_eligibility -> planning) when holds absent and approvals present

transition(planning -> crypto_erase) when encryption_at_rest=true and KEK valid

transition(planning -> executing_purge) when media supports purge and crypto-erase not viable

transition(planning -> executing_destroy) when policy/jurisdiction requires physical destruction

transition(crypto_erase|executing_* -> verifying) when orchestrator ACK received

transition(verifying -> issuing_certificate) when verification checks pass

transition(evaluating_eligibility -> exception_open) when hold/constraint blocks action

transition(any -> contestation_workflow) when PolicyDispute opened

transition(* -> failed) on validation error or orchestrator NACK>5

timeout(executing_destroy, 2h) -> failed; retry<=1 after human review

idempotency_key = sha256(asset_ref, method, start_ts_floor_1m)

Output Contracts Summary [Normative]

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-1 WipeCertificate	Required	Always	Authoritative proof of sanitization
OC-2 WipeException	Conditionally Required	Holds/constraints prevent wipe or deferral requested	Governance and SLA protection
OC-3 PolicyDispute	Optional	Contestability enabled	Arbitration and explainability
OC-4 IRPolicyViolationEvent	Optional	IR/SIEM integration present	Incident response integration
OC-5 ChangeImpactReport	Conditionally Required	Program impact/tuning enabled	Program risk/throughput management
OC-6 FeedbackIngestionEvent	Optional	Reviewer feedback workflow enabled	Continuous improvement

Requirement Level Definitions:

- **Required:** Must be implemented for conformant deployment
- **Conditionally Required:** Must be implemented when trigger condition is met
- **Optional:** May be implemented for enhanced functionality

Policies and HITL gates [Informative]

- **policy_refs:** MP-6 (Media Sanitization), MP-5, SC-12/SC-28; org retention & sanitization policy; records governance.
- **HITL required:** physical destruction and custody witnessing; overrides to proceed within legal hold windows; off-facility transport.
- **Automatic HITL escalation triggers:** model_confidence < theta_low; custody_chain incomplete; facility jurisdiction mismatch; attempted wipe under active hold.

SLOs and KPIs [Informative]

- WipeCertIssue_p95 <= 10 min after verify complete
- ExceptionRouting_p95 <= 5 min
- CustodyBreakDetect_MTTD <= 5 min
- LegalHoldBlockRate (true positives) >= 99.9 percent
- ReworkRate_30d (verification failed) <= 0.5 percent

Outputs index [Informative]

[OC-1 WipeCertificate], [OC-2 WipeException], [OC-3 PolicyDispute], [OC-4 IRPolicyViolationEvent], [OC-5 ChangeImpactReport], [OC-6 FeedbackIngestionEvent]

Technical Implementation Details (F4) [Informative]

Model and training profile [Informative]

model_id=secure-wipe-text-model; temperature=0.1; max_tokens_out=600
prompt_pack_id=disposition-v1 (NIST 800-88r1 rubric, custody, legal-hold/records policy)
RAG: sources={CMDB, ITSM, records policies, KMS catalog, facility constraints, prior certificates}; max_docs=12; min_similarity=0.78; citations required
fine_tuning/adapters: optional on synthetic device inventories; never on real media contents
guardrails: legal_hold_check=true; two_person_rule:true on destructive paths;
allowlisted orchestrators only

Memory and state [Informative]

working_memory.max_tokens=4k; eviction=recency_then_importance
episodic_memory: per mission_id journal (orders, holds, proofs); ttl=365d
semantic_memory:
namespaces=["assets","records_policies","kms","facilities","certificates"];
embeddings=text-embedding-sec-v1; k=8
durable_state_store: event-sourced journal; snapshot at each certificate issuance
consistency: at-least-once (exceptions/reports); exactly-once (certificate IDs)
idempotency: as per Output Contracts

Decision and routing logic [Informative]

$$\text{wipe_risk_score} = 0.35\text{data_sensitivity} + 0.25\text{media_recoverability} + 0.2\text{facility_custody_risk} + 0.1\text{jurisdictional_risk} + 0.1 \cdot (1 - \text{method_confidence})$$

where

data_sensitivity in {0.2 public, 0.6 internal, 1.0 restricted}
media_recoverability in {0.2 for SSD w/ crypto-erase viable, 0.6 for HDD purge, 1.0 for unknown/legacy}
facility_custody_risk = indicator(custody_chain incomplete)
jurisdictional_risk = indicator(special disposal laws apply)
action selection:

- if legal_hold=true then emit WipeException and block
- else choose method with min residual risk meeting policy (prefer CryptoErase→Purge→Destroy); require HITL for Destroy

Model Risk Management [Informative]

continuous_validation: daily goldens + adversarial “ambiguous hold” cases
thresholds: eval_pass_rate >= 99.5 percent → else auto_HITL
red_team_cycle: monthly custody tamper and forged certificate simulations
rollback_policy: eval_drop >= 1.5 percentage points for 48 h → revert
model/prompt_pack; notify owners

Transparency and Audit Trail (Approver/Auditor UX) [Informative]

decision_rationale_template: who/what/when/where/why; method justification;
evidence_refs; custody hashes; signer KIDs
UI/API: expose classification_label, provenance.attestation, decision_rationale_url
audit_log_format: JSONL, stable field order; retain per legal_hold and records policy

Incident Response Integration [Informative]

emit OC-4 on attempted wipe under hold or custody break; attach ITSM/records/KMS evidence

Change Impact Assessment [Informative]

emit OC-5 with assets_processed, methods_breakdown, exception hot-spots; inform capacity planning and facility scheduling

Stakeholder Feedback Loop [Informative]

emit OC-6 from Records/Facilities portals; labels={helpful|neutral|harmful}; use to refine method selection rules after governance review

Data Sovereignty and Legal Hold [Informative]

enforce region/facility constraints; prohibit cross-border media transfer without approvals; freeze purge/destroy when legal_hold=true

Interfaces (links only) [Informative]

Consumes: ITSM/CMDB decommission orders; Records/ILM expiry events

Produces: OC-1, OC-2 (+ optional OC-3..OC-6)

Safety and abuse prevention [Informative]

kill_switch on unexpected destroy volume spikes; sandbox for new device classes; blast-radius caps for simultaneous destroys per facility

Testing and validation [Informative]

contract tests for OC-1/OC-2; offline replay of orders/ILM events; custody break drills; drift checks and rollback

Deployment and lifecycle [Informative]

workers per facility/region; backpressure on orchestrator queues; canary runs; SBOM + attestations; sign all outputs

References / Standards [Informative]

NIST SP 800-160 Vol. 2; NIST SP 800-88r1; NIST SP 800-53 Rev. 5 (MP-6, MP-5, SC-12, SC-28); ISO/IEC 27040; NIST CSF 2.0; ISO/IEC 27002:2022; CIS Controls v8

MCP-Native Protocol Specification (F4) [Normative]

- **Native Protocol(s) Consumed:** ITSM/CMDB Decommission Orders; Records Mgmt / Object-Store ILM Retention Expiry Events
- **Native Protocol(s) Produced:** **WipeCertificate** (REST/Kafka); **WipeException** (REST/Kafka, optional)
- **MCP Context Fields:**
 - **Required:** mission_id; role="SecureWipeAgent"; intent="dispose"; policy_refs; **legal_hold_check=true**; provenance (SPIFFE ID, signing KID, attestation)
 - **Optional:** constraints; classification; decision_basis; region; facility_id
- **Enforcement Note:** Orchestrators must verify provenance.attestation, two-person signatures for destructive methods, custody capture online, and legal-hold clearance before execution.
- **Versioning and compatibility; producers/consumers registry:** authoritative in schema registry; see Schema Capsules for accepted ranges/EOL dates.

- **Example payloads:** authoritative native + MCP-wrapped examples as provided above.
- **Transparency hooks:** `classification_label`, `provenance.attestation`, `decision_rationale_url` available to downstream UIs/APIs.

Conformance: This section is **[Normative]** and, together with each **Schema Capsule**, defines testable requirements.

F5. Integrity Monitor Agent

Agent Blueprint [Informative]

Purpose: Continuously verify data/system integrity via checksum comparison and signed “integrity beacons”; detect tampering in data sets, binaries, containers, and hosts; emit **IntegrityAlert** with explicit validation method and evidence chain.

Operational Narrative [Informative]

Inputs used (authoritative sources):

- **Checksums / Manifests (REST/Repo APIs/Package Indexes):** expected digests for artifacts (files, packages, container layers, datasets), manifest locations, source commit references, SBOM pointers.
- **Integrity Beacons / Host Attestations (signed):** periodic, signed heartbeats carrying TPM quotes/PCRs, secure boot and measured-boot state, build/provenance attestations (e.g., SLSA/Intoto).

Model training / knowledge (what the LLM relies on):

- Prompt pack for integrity controls (NIST 800-53 SI-7; platform guidance 800-193; supply-chain 800-161), digest/attestation verification patterns, SBOM/digest mapping rules.
- RAG sources: artifact registry manifests, SBOM catalog, golden-PCR baselines per platform, build attestation store, host inventory, previous IntegrityAlerts.
- Guardrails: only accept cryptographic verification methods listed in allowlist; do not fetch or store raw sensitive payloads; enforce read-only access to artifact stores; strict timeout/latency SLOs for online verification.

Decisions it makes (deterministic + model-assisted):

- **Validation verdict:** match, mismatch, unverifiable, stale-baseline; for beacons: `attested_ok`, `policy_mismatch`, `signature_invalid`, `replay_suspected`.

- **Severity & routing:** compute integrity_severity_score and decide: silent_ok, summary_only, alert (IntegrityAlert), or escalate (IR event + quarantine request to SOAR/EDR).
- **Baseline hygiene:** open change to refresh golden digests or measured-boot baselines when signed/approved releases advance.
- **Explainability:** compile decision rationale including validation_method, evidence_refs, and confidence.

Routing / where outputs go:

- **IntegrityAlert** → Kafka/AMQP to SIEM/SOAR and owners; optional ContainmentRequest to orchestrators (quarantine/denylist), per policy.
- **IntegrityStatus (periodic)** → CMDB/graph for posture dashboards and dependency reasoning.
- **Tickets/alerts** → create issues for stale or missing manifests/attestations; raise PolicyDispute when owners contest a mismatch.

Automation scope vs. manual/HITL:

- Fully automated: digest/attestation checks, alert emission, status summaries, baseline freshness checks, evidence journaling.
- **HITL required:** quarantine/rollback on CrownJewels; replacing golden baselines when provenance is ambiguous; overrides after repeated false positives.
- Manual outside agent: vendor firmware attestation exceptions; post-incident forensics beyond evidence linking.

Security Domain: Data Security & Privacy

Inputs (native protocols consumed) [Informative]

1. **Checksums / Manifests (REST/Repo APIs/Package Indexes)** — expected hashes for artifacts & datasets
2. **Integrity Beacons / Host Attestations (signed)** — proof-of-state (TPM quotes, secure boot, build attestations)

Example: Consumed Protocol 1 — Checksums / Manifests (container image layer)

[Informative]

Native payload

```
{
```

```

"artifact_type": "container_image",
"image": "registry.corp.example/payments/api:1.4.2",
"layer_digest_observed": "sha256:8a1f...b9ce",
"layer_digest_expected": "sha256:8a1f...b9ce",
"manifest_ref": "uri://registry/manifest/payments/api:1.4.2",
"source_repo": "git@code.example/payments/api",
"commit": "7e3c1b2",
"scan_ts": "2025-08-15T14:40:11Z",
"hash_alg": "sha256",
"size_bytes": 254331987
}

```

MCP-wrapped payload

```

{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-f5-chk-1111-2222-3333-4444",
    "thread_id": "uuid-image-registry.corp.example-payments-api-1.4.2",
    "task_id": "uuid-a1b2-c3d4-e5f6-7788",
    "role": "IntegrityMonitorAgent",
    "intent": "verify",
    "policy_refs": ["SI-7", "SC-13", "SA-10"],
    "decision_basis": {
      "validation_method": "checksum_match(sha256)",
      "evidence_refs": [
        "uri://registry/manifest/payments/api:1.4.2",
        "digest://sha256/8a1f...b9ce",
        "git://code.example/payments/api@7e3c1b2"
      ]
    }
  }
}

```

```

    ],
    "confidence": 0.99,
    "explanation_ref": "uri://kb/integrity/checksum-validation#container-layers"
  },
  "provenance": {
    "producer_spiffe": "spiffe://enterprise/data/integrity-monitor-agent",
    "signing_kid": "kid-chk-f5-01",
    "attestation_ref": "uri://slsa/attestations/integrity-monitor@sha256:chk01"
  },
  "classification": "C1",
  "legal_hold": false,
  "constraints": ["alert_on_mismatch_only:true"]
},
"native_payload": { ... }
}

```

Example: Consumed Protocol 2 — Integrity Beacons / Host Attestations (signed)

[Informative]

Native payload

```

{
  "beacon_id": "beacon-srv-001-2025-08-15T14:41:05Z",
  "host_id": "srv-001",
  "nonce": "e6c1b4d9efad4a4b",
  "timestamp": "2025-08-15T14:41:05Z",
  "platform": {"os": "ubuntu", "kernel": "6.6.12", "secure_boot": true},
  "measurements": {
    "tpm_pcrs": {"0": "3b24...", "7": "89fe...", "11": "a1c2..."},
    "bootloader_hash": "sha256:4f7a...11e8",
    "measured_boot_policy": "baseline-2025-06"
  }
}

```

```

},
"signature": {
  "alg": "ed25519",
  "pubkey_fp": "fp:ed25519:5c:2a:7b:91",
  "sig_b64": "m4QdJ7...xYk="
},
"attestor_chain": [
  "spiffe://enterprise/hosts/srv-001",
  "attest://tpm/ekcert/issuer:OEM-TPM-CA"
],
"beacon_schema": "v1.2.0"
}

```

MCP-wrapped payload

```

{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-f5-bcn-5555-6666-7777-8888",
    "thread_id": "uuid-beacon-srv-001-2025-08-15T14:41:05Z",
    "task_id": "uuid-99aa-bbcc-ddee-ff00",
    "role": "IntegrityMonitorAgent",
    "intent": "verify",
    "policy_refs": ["SI-7", "SC-13", "SC-17"],
    "decision_basis": {
      "validation_method": "signature_verify(ed25519)+TPM_PCR_policy_match",
      "evidence_refs": [
        "uri://beacons/srv-001/2025-08-15T14:41:05Z",
        "uri://policies/measured-boot/baseline-2025-06",

```

```

    "attest://tpm/ekcert/issuer:OEM-TPM-CA"
  ],
  "confidence": 0.96,
  "explanation_ref": "uri://kb/integrity/host-attestation#tpm-pcr"
},
"provenance": {
  "producer_spiffe": "spiffe://enterprise/data/integrity-monitor-agent",
  "signing_kid": "kid-bcn-f5-02",
  "attestation_ref": "uri://slsa/attestations/integrity-monitor@sha256:bcn02"
},
"classification": "C2",
"legal_hold": false
},
"native_payload": { ... }
}

```

Outputs (native) [Informative]

- **IntegrityAlert (Kafka/AMQP):** asset/scope, verdict, validation_method, evidence_refs, severity, recommended_action, provenance.
- **IntegrityStatus (Kafka/REST, periodic, optional):** posture summaries by asset/artifact (match/mismatch/unverified), baseline age, coverage.

MCP context (required) [Informative]

mission_id; role="IntegrityMonitorAgent"; intent="verify"; **policy_refs** (must include SI-7; add SC-13/SC-28/SA-10/SC-17 as applicable); **decision_basis** (validation_method, evidence_refs, confidence); provenance (SPIFFE ID, signing KID, attestation)

MCP context (optional) [Informative]

classification (C1–C3); constraints (e.g., alert_on_mismatch_only:true, latency_slo_ms:5000); legal_hold; region; environment; asset_owner

Enforcement note [Informative]

Consumers (SIEM/SOAR/PEPs) must require **decision_basis.validation_method** to be a cryptographic method (checksum_match, signature_verify, attestation_verify) and must verify **provenance.attestation** before acting on quarantine/rollback recommendations.

NIST SP 800-160v2 linkage [Informative]

Implement & Maintain — engineer integrity as a resilience mechanism with verified evidence chains and provenance.

Automation feasibility [Informative]

High (verification and alerting fully automatable; HITL only for risky remediations or baseline resets).

Output Contracts (merged) [Informative]

OC-1: IntegrityAlert [Informative]

- **Producer(s):** F5
- **Topic/Path:** Kafka sec.integrity.alert (or AMQP equivalent)
- **Schema/Format:** IntegrityAlert@1.0 { alert_id, asset_ref, scope in {"dataset","binary","container","host"}, verdict in {"match","mismatch","unverifiable","policy_mismatch","replay_suspected"}, validation_method, evidence_refs[], severity in {low,med,high,critical}, recommended_action?, baseline_ref?, decision_rationale_url?, provenance.attestation, emitted_ts }
- **Classification:** C1 (metadata) → C2 when topology or sensitive artifact paths included
- **Delivery:** at-least-once
- **Ordering:** per-asset_ref
- **Idempotency-Key:** sha256(asset_ref, scope, validation_method, evidence_hash_floor_1m)
- **Ack/Nack:** broker ACK; retry exp-backoff<=5x; on repeated NACK → HITL escalation
- **Side-Effects:** open or update SIEM case; optional ContainmentRequest to SOAR/EDR for CrownJewels per policy
- **HITL Token:** required for quarantine/rollback on CrownJewels

- **Observability:** trace_id, mission_id, policy_refs, decision_basis.*, classification_label, provenance.attestation
- **Retention/TTL:** 1 year (or per IR policy)

Schema Capsule (OC-1) [Normative]

Requirement Level: Required

Condition: Always

schema_id=IntegrityAlert@1.0 | json_schema_uri=uri://schema/integrity-alert-1.0.json | sha256= | producers=F5 | consumers=SIEM-01, SOAR-01, Owners-01 | accepts=1.0–1.x

Conformance: This capsule and the corresponding MCP schema define testable requirements.

OC-2: IntegrityStatus (Periodic Summary) [Informative]

- **Producer(s):** F5
- **Topic/Path:** Kafka sec.integrity.status or REST POST /integrity/status
- **Schema/Format:** IntegrityStatus@1.0 { snapshot_ts, asset_ref|service_ref, coverage_percent, last_match_ts?, last_mismatch_ts?, baseline_age_days, unverifiable_count, beacon_health in {ok,stale,missing}, notes? }
- **Classification:** C1
- **Delivery:** at-least-once
- **Ordering:** per-asset_ref
- **Idempotency-Key:** sha256(asset_ref, snapshot_ts_floor_1h)
- **Ack/Nack:** broker/2xx ACK; retry/backoff
- **Side-Effects:** update CMDB/graph; drive SLO dashboards; trigger baseline refresh tasks if stale
- **HITL Token:** none
- **Observability:** trace_id, mission_id, policy_refs, provenance.attestation
- **Retention/TTL:** 1 year

Schema Capsule (OC-2) [Normative]

Requirement Level: Conditionally Required

Condition: When CMDB/graph posture integration is enabled

schema_id=IntegrityStatus@1.0 | json_schema_uri=uri://schema/integrity-status-

1.0.json | sha256= | producers=F5 | consumers=CMDB-01, Dash-01 | accepts=1.0–1.x
Conformance: Normative when condition is met.

OC-3: PolicyDispute (Explainability and Contestability) [Informative, optional]

- **Producer(s):** F5; Owner/Release portals
- **Topic/Path:** sec.integrity.contestation
- **Schema/Format:** PolicyDispute@1.0 (asset_ref, dispute_reason, business_justification, approver_chain, decision_rationale_url)

Schema Capsule (OC-3) [Normative]

Requirement Level: Optional

Condition: When contestability workflow is enabled

schema_id=PolicyDispute@1.0 | json_schema_uri=uri://schema/policy-dispute-1.0.json

OC-4: IRPolicyViolationEvent (Incident Response Integration) [Informative, optional]

- **Producer(s):** F5
- **Topic/Path:** sec.integrity.ir_event
- **Schema/Format:** IRPolicyViolationEvent@1.0 (artifact_tamper_detected, signature_invalid, replay_suspected, host_attestation_failed)

Schema Capsule (OC-4) [Normative]

Requirement Level: Optional

Condition: When IR/SIEM integration is present

schema_id=IRPolicyViolationEvent@1.0 | json_schema_uri=uri://schema/ir-policy-violation-1.0.json

OC-5: ChangeImpactReport (Integrity Baseline & Coverage Management) [Informative, optional]

- **Producer(s):** F5
- **Topic/Path:** sec.integrity.change_impact
- **Schema/Format:** ChangeImpactReport@1.0 (baselines_outdated_count, services_affected, coverage_gaps_by_domain, recommended_refreshes[])

Schema Capsule (OC-5) [Normative]

Requirement Level: Conditionally Required

Condition: When integrity coverage/refresh scoring is enabled

schema_id=ChangeImpactReport@1.0 | json_schema_uri=uri://schema/change-impact-1.0.json

OC-6: FeedbackIngestionEvent (Stakeholder Feedback Loop) [Informative, optional]

- **Producer(s):** Owner/Release portals; F5 (aggregation)
- **Topic/Path:** sec.integrity.feedback
- **Schema/Format:** FeedbackIngestionEvent@1.0
(labels={helpful|neutral|harmful}, artifact_refs, notes)

Schema Capsule (OC-6) [Normative]

Requirement Level: Optional

Condition: When reviewer feedback workflow is enabled

schema_id=FeedbackIngestionEvent@1.0 | json_schema_uri=uri://schema/feedback-ingestion-1.0.json

State machine (concise) [Informative]

states = { idle, pulling_manifests, receiving_beacons, verifying, alerting, summarizing, contestation_workflow, rolled_back, failed, closed }

transition(idle -> pulling_manifests) on schedule or new release detected

transition(idle -> receiving_beacons) when host beacons arrive

transition(pulling_manifests|receiving_beacons -> verifying) when evidence set complete or timeout

transition(verifying -> alerting) when verdict in {mismatch, policy_mismatch, signature_invalid, replay_suspected}

transition(verifying -> summarizing) when periodic window reached or silent_ok

transition(alerting -> contestation_workflow) when PolicyDispute opened

transition(* -> failed) on schema/attestation validation error or broker NACK>5

timeout(verifying, latency_slo_ms) -> alerting (severity=high, reason=unverifiable)

idempotency_key = sha256(asset_ref, scope, validation_method,

evidence_hash_floor_1m)

Output Contracts Summary [Normative]

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-1 IntegrityAlert	Required	Any mismatch/policy failure/unverifiable critical asset	Rapid detection and response
OC-2 IntegrityStatus	Conditionally Required	CMDB/graph posture integration enabled	Posture visibility & reporting
OC-3 PolicyDispute	Optional	Contestability enabled	Governance & arbitration
OC-4 IRPolicyViolationEvent	Optional	IR/SIEM integration present	Incident response integration
OC-5 ChangeImpactReport	Conditionally Required	Coverage/refresh scoring enabled	Risk & change management
OC-6 FeedbackIngestionEvent	Optional	Reviewer feedback workflow enabled	Continuous improvement

Requirement Level Definitions:

- **Required:** Must be implemented for conformant deployment
- **Conditionally Required:** Must be implemented when trigger condition is met
- **Optional:** May be implemented for enhanced functionality

Policies and HITL gates [Informative]

- **policy_refs:** SI-7 (software/firmware/information integrity), SC-13/SC-28 (crypto protections), SA-10 (developer testing), SC-17 (public key infrastructure); org baselines for beacons/digests.
- **HITL required:** quarantine or rollback on CrownJewels; baseline resets when provenance unclear; overrides after repeated false positives.
- **Automatic HITL escalation triggers:** model_confidence < theta_low; replay_suspected=true; beacon_health=missing for >2 intervals on CrownJewels; unverifiable_count spikes.

SLOs and KPIs [Informative]

- IntegrityDetect_p95 (from evidence arrival) <= 30 s
- FalseAlertRate_7d <= 1 percent
- BaselineFreshness_p95 <= 7 days for active services
- CoveragePercent (artifact classes under verification) >= 95 percent
- ReplayDetect_MTTD <= 5 min

Outputs index [Informative]

[OC-1 IntegrityAlert], [OC-2 IntegrityStatus], [OC-3 PolicyDispute], [OC-4 IRPolicyViolationEvent], [OC-5 ChangeImpactReport], [OC-6 FeedbackIngestionEvent]

Technical Implementation Details (F5) [Informative]

Model and training profile [Informative]

model_id=integrity-monitor-text-model; temperature=0.05; max_tokens_out=500
 prompt_pack_id=integrity-rubric-v1 (SI-7 rubric, checksum/attestation patterns, replay detection)

RAG: sources={artifact manifests, SBOMs, golden PCR baselines, build attestations, host inventory}; max_docs=12; min_similarity=0.8; citations required
 fine_tuning/adapters: optional on synthetic mismatch corpora; exclude regulated content
 guardrails: allowed_validation_methods={checksum_match, signature_verify, attestation_verify}; deny heuristic-only verdicts

Memory and state [Informative]

working_memory.max_tokens=4k; eviction=recency_then_importance
 episodic_memory: per mission_id journal of verifications and alerts; ttl=365d
 semantic_memory:
 namespaces=["artifacts","sboms","attestations","pcr_baselines","owners"];
 embeddings=text-embedding-sec-v1; k=8
 durable_state_store: event-sourced; snapshot daily and at release boundaries
 consistency: at-least-once (status); exactly-once (alert dedupe by idempotency key)
 idempotency: per Output Contracts

Decision and routing logic [Informative]

$\text{integrity_severity_score} = 0.35\text{asset_criticality} + 0.25\text{verification_gap} + 0.2\text{exposure} + 0.1\text{history_factor} + 0.1 \cdot (1 - \text{confidence})$

where

asset_criticality in {0.2 low, 0.6 med, 1.0 high}

verification_gap = indicator(validation_method is not cryptographic or baseline stale)

exposure in {0.2 internal, 0.6 partner, 1.0 internet_facing}
history_factor = min(1.0, recent_mismatch_rate_30d)
routing:

- if verdict=mismatch or signature_invalid → emit IntegrityAlert; if CrownJewels → recommend quarantine (HITL gate).
- if verdict=unverifiable and asset_criticality=high → severity >= high; open IR event.
- if verdict=match → update IntegrityStatus; silent_ok if alert_on_mismatch_only=true.

Model Risk Management [Informative]

continuous_validation: daily goldens + adversarial replay/rename/substitution sets
thresholds: eval_pass_rate >= 99.5 percent → else auto_HITL
red_team_cycle: monthly supply-chain and beacon-replay simulations
rollback_policy: eval_drop >= 1.5 percentage points for 48 h → revert
prompt_pack/model; notify owners

Transparency and Audit Trail (Approver/Auditor UX) [Informative]

decision_rationale_template: asset, scope, verdict, validation_method, evidence_refs, baseline_ref, computed severity, hashes
UI/API: expose classification_label, provenance.attestation, decision_rationale_url
audit_log_format: JSONL, stable field order; retention per classification and legal_hold

Incident Response Integration [Informative]

emit IRPolicyViolationEvent (OC-4) on mismatch/signature_invalid/replay_suspected;
attach evidence and suggested playbook (quarantine/rollback)

Change Impact Assessment [Informative]

emit ChangeImpactReport (OC-5) with baselines_outdated_count and coverage_gaps;
gate releases if coverage < target

Stakeholder Feedback Loop [Informative]

emit FeedbackIngestionEvent (OC-6); labels={helpful|neutral|harmful}; use to tune alert thresholds and baseline-refresh cadence after governance review

Data Sovereignty and Legal Hold [Informative]

respect region constraints on evidence storage; set legal_hold=true for investigation-linked alerts; freeze baseline changes under hold

Interfaces (links only) [Informative]

Consumes: Checksums/Manifests; Integrity Beacons/Host Attestations

Produces: OC-1, OC-2 (+ optional OC-3..OC-6)

Safety and abuse prevention [Informative]

kill_switch on alert storm; rate-limit per asset; sandbox new beacon schemas; strict clock-skew tolerance for replay detection

Testing and validation [Informative]

contract tests (OC-1/OC-2); offline replay of mismatches; synthetic beacon replays; drift checks and rollback

Deployment and lifecycle [Informative]

horizontally scalable workers; backpressure when registry/beacon endpoints slow; canary enablement by asset class; SBOM + attestations; sign all outputs

References / Standards [Informative]

NIST SP 800-160 Vol. 2; NIST SP 800-53 Rev. 5 (SI-7, SC-13, SC-28, SA-10, SC-17); NIST SP 800-193; NIST SP 800-161; NIST CSF 2.0; ISO/IEC 27002:2022; CIS Controls v8

MCP-Native Protocol Specification (F5) [Normative]

- **Native Protocol(s) Consumed:** Checksums/Manifests (REST/Repo APIs/Package Indexes); Integrity Beacons/Host Attestations (signed)
- **Native Protocol(s) Produced:** **IntegrityAlert** (Kafka/AMQP); **IntegrityStatus** (Kafka/REST, optional)
- **MCP Context Fields:**
 - **Required:** mission_id; role="IntegrityMonitorAgent"; intent="verify"; policy_refs (must include SI-7); decision_basis (validation_method, evidence_refs, confidence); provenance (SPIFFE ID, signing KID, attestation)
 - **Optional:** classification; constraints; legal_hold; region; environment; asset_owner
- **Enforcement Note:** Consumers must verify provenance.attestation and require cryptographic **validation_method** values before acting on recommended remediations.

- **Versioning and compatibility; producers/consumers registry:** authoritative in schema registry; see Schema Capsules for accepted ranges/EOL dates.
- **Example payloads:** authoritative native + MCP-wrapped examples as provided above.
- **Transparency hooks:** `classification_label`, `provenance.attestation`, `decision_rationale_url` exposed to downstream UIs/APIs.

Conformance: This section is **[Normative]** and, together with each **Schema Capsule**, defines testable requirements.

F6. Privacy Enforcement Agent

Agent Blueprint [Informative]

Purpose: Enforce privacy-enhancing technologies (PETs) such as tokenization, differential privacy, k-anonymity, masking, and generalization within data pipelines; ensure processing aligns to jurisdictional policies and declared purposes; emit **PETApplicationResult**.

Operational Narrative [Informative]

Inputs used (authoritative sources):

- **Data Pipelines (Airflow/dbt/Spark/Kafka/Beam manifests):** job lineage, stage, schemas, fields and types, destinations and regions, owners, environment tags.
- **Privacy Policies (Policy Registry/OPA/Legal Catalog):** purpose-based rules, lawful basis matrix, PET requirements by data category, parameter bounds (k, epsilon), retention, and cross-border constraints.

Model training / knowledge (what the LLM relies on):

- Prompt pack for purpose-based privacy engineering (GDPR Arts. 5/6/25, NIST IR 8062, ISO/IEC 27555), PET selection rubric, cross-border decision tree, and retention mapping.
- RAG sources: policy registry, pipeline catalog, data classification catalog, historical PET decisions and exceptions.
- Guardrails: deny execution if lawful basis unknown or cross-border constraint violated; enforce parameter ceilings (`dp_epsilon_max`) and floors (`k_min`); allowlisted pipeline orchestrator endpoints only.

Decisions it makes (deterministic + model-assisted):

- **Purpose-lawfulness check:** verify lawful basis and declared purpose match policy for the pipeline and subject regions.

- **PET selection and parameterization:** choose tokenization vs masking vs generalization vs DP vs k-anonymity per field category and policy; compute parameters within bounds.
- **Routing and enforcement:** inject transforms into jobs or block with **PrivacyException**; ensure region routing meets constraints; set retention controls.
- **Explainability:** compile rationale including policy_refs, evidence_refs, chosen PETs, and parameter math.

Routing / where outputs go:

- **PETApplicationResult** → REST/Kafka to pipeline orchestrator and catalog; back-annotate lineage with applied PETs and parameters; update evidence registry.
- **PrivacyException** (on block/denial) → exception queue and change-management workflow; notify owners/privacy officer.
- **Tickets/alerts** → open issues for pipelines lacking purpose labels or violating cross-border rules.

Automation scope vs. manual/HITL:

- Fully automated: purpose-lawful basis checks, PET selection, parameter computation, transform injection for supported engines, region routing checks, result emission.
- **HITL required:** overrides that raise epsilon above policy, k below policy, or allow cross-border transfer when no_cross_border_transfer:true; dataset re-identification risk flagged by heuristics; exceptions for CrownJewels datasets.
- Manual outside agent: bespoke PET algorithm development; DPIA creation beyond structured fields.

Security Domain: Data Security & Privacy

Inputs (native protocols consumed) [Informative]

1. **Data Pipelines (Airflow/dbt/Spark/Kafka/Beam REST & event manifests)** — job lineage, schemas, destinations, regions
2. **Privacy Policies (Policy Registry/OPA/Legal Catalog REST)** — purpose-based rules, lawful basis, PET requirements, retention

Example: Consumed Protocol 1 — Data Pipelines (manifest) [Informative]

Native payload

```
{
  "pipeline_id": "etl-payments-daily",
  "engine": "spark",
  "job_id": "run-2025-08-15T14:55:00Z",
  "stage": "write",
  "source": {
    "dataset": "payments.customers_raw",
    "fields": [
      {"name": "customer_id", "type": "string"},
      {"name": "email", "type": "string"},
      {"name": "ssn", "type": "string"},
      {"name": "amount_usd", "type": "decimal(18,2)"},
      {"name": "country", "type": "string"}
    ]
  },
  "destination": {
    "dataset": "analytics.customers_daily",
    "storage": "s3://eu-analytics/customers_daily/",
    "region": "eu-central-1"
  },
  "lineage": ["extract_customers", "cleanse_pii", "join_payments"],
  "tags": ["prod", "pii_present", "pci_adjacent"],
  "owner": "data.payments"
}
```

MCP-wrapped payload

```
{
```

```

"mcp_context": {
  "mcp_version": "0.9",
  "mission_id": "uuid-f6-pipe-1111-2222-3333-4444",
  "thread_id": "uuid-etl-payments-daily-run-2025-08-15T14:55:00Z",
  "task_id": "uuid-a1b2-c3d4-e5f6-7788",
  "role": "PrivacyEnforcementAgent",
  "intent": "enforce",
  "jurisdiction": "EU",
  "data_subject_region": ["EU"],
  "legal_basis": "contract",
  "purpose": "order_fulfillment_analytics",
  "policy_refs": ["GDPR-ART-5", "GDPR-ART-25", "ORG-PRIV-TRANSFORM-01"],
  "constraints": ["mask_in_nonprod:true", "no_cross_border_transfer:true", "k_min:10",
"dp_epsilon_max:1.0"],
  "decision_basis": {
    "evidence_refs": [
      "uri://airflow/jobs/etl-payments-daily/run-2025-08-15T14:55:00Z",
      "uri://catalog/schema/payments.customers_raw",
      "uri://catalog/schema/analytics.customers_daily"
    ],
    "confidence": 0.95,
    "explanation_ref": "uri://kb/privacy/pipeline-pet-selection#payments"
  },
  "provenance": {
    "producer_spiffe": "spiffe://enterprise/data/privacy-enforcement-agent",
    "signing_kid": "kid-pipe-f6-01",
    "attestation_ref": "uri://slsa/attestations/privacy-enforce@sha256:pipe01"
  },

```

```

    "classification": "C2",
    "legal_hold": false
  },
  "native_payload": { ... }
}

```

Example: Consumed Protocol 2 — Privacy Policies (policy rule) [Informative]
Native payload

```

{
  "policy_id": "POL-PRIV-ETL-PETS-01",
  "effective": "2025-06-01",
  "jurisdictions": ["EU", "US-CA"],
  "purpose": "order_fulfillment_analytics",
  "lawful_bases": ["contract", "legitimate_interest"],
  "data_categories": {
    "email": {"classification": "PII", "pet": "tokenization"},
    "ssn": {"classification": "Sensitive PII", "pet": "format_preserving_tokenization"},
    "amount_usd": {"classification": "Financial", "pet": "none"},
    "country": {"classification": "General", "pet": "generalization_2level"}
  },
  "parameters": {
    "k_min": 10,
    "dp_epsilon_max": 1.0,
    "retain_days_max": 365
  },
  "cross_border_rules": {"EU->nonEU": "deny"},
  "approvers": ["privacy.officer", "data.governance.lead"]
}

```

MCP-wrapped payload

```

{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-f6-pol-5555-6666-7777-8888",
    "thread_id": "uuid-policy-POL-PRIV-ETL-PETS-01",
    "task_id": "uuid-99aa-bbcc-ddee-ff00",
    "role": "PrivacyEnforcementAgent",
    "intent": "enforce",
    "jurisdiction": ["EU", "US-CA"],
    "legal_basis": ["contract", "legitimate_interest"],
    "purpose": "order_fulfillment_analytics",
    "policy_refs": ["GDPR-ART-5", "GDPR-ART-6", "GDPR-ART-25", "NIST-IR-8062"],
    "constraints": ["k_min:10", "dp_epsilon_max:1.0", "no_cross_border_transfer:true"],
    "decision_basis": {
      "evidence_refs": ["uri://policy/registry/POL-PRIV-ETL-PETS-01"],
      "confidence": 0.97,
      "explanation_ref": "uri://kb/privacy/purpose-and-lawful-basis-matrix"
    },
    "provenance": {
      "producer_spiffe": "spiffe://enterprise/data/privacy-enforcement-agent",
      "signing_kid": "kid-pol-f6-02",
      "attestation_ref": "uri://slsa/attestations/privacy-enforce@sha256:pol02"
    },
    "classification": "C2",
    "legal_hold": false
  },
  "native_payload": { ... }
}

```

}

Outputs (native) [Informative]

- **PETApplicationResult (REST/Kafka):** dataset/fields transformed, PET type, parameters (epsilon, k, suppression, noise scale), residual risk notes, provenance.
- **PrivacyException (REST/Kafka, optional):** emitted when policy or constraints block processing or PET cannot be applied safely.

MCP context (required) [Informative]

mission_id; role="PrivacyEnforcementAgent"; intent="enforce"; jurisdiction; legal_basis; purpose; data_subject_region; policy_refs; provenance (SPIFFE ID, signing KID, attestation)

MCP context (optional) [Informative]

classification (often C2–C3); constraints (e.g., dp_epsilon_max, k_min, no_cross_border_transfer, mask_in_nonprod); decision_basis (evidence_refs, confidence, explanation_ref); legal_hold

Enforcement note [Informative]

PEPs in orchestrators must verify provenance.attestation, reject transfers where no_cross_border_transfer:true and destination region not allowed, enforce epsilon <= dp_epsilon_max and k >= k_min, and deny moves lacking lawful basis or declared purpose.

NIST SP 800-160v2 linkage [Informative]

Implement and Maintain — privacy-preserving resilience and data minimization as architectural strategy.

Automation feasibility [Informative]

High (policy-driven transforms, parameter selection, and routing checks); exceptions and high-risk overrides are HITL-gated.

Output Contracts (merged) [Informative]

OC-1: PETApplicationResult [Informative]

- **Producer(s):** F6
- **Topic/Path:** REST POST /privacy/pet-result, Kafka sec.privacy.pet_application_result

- **Schema/Format:** PETApplicationResult@1.0 { result_id, pipeline_id, job_id, source_dataset, destination_dataset, jurisdiction[], legal_basis, purpose, fields_applied[{name, pet, params{epsilon?,k?,mask?,generalization_level?,noise_scale?}, method_version}], residual_risk_notes?, retention_applied_days?, region_route{from,to,allowed}, decision_rationale_url?, provenance.attestation, emitted_ts }
- **Classification:** C2
- **Delivery:** at-least-once
- **Ordering:** per-pipeline_id
- **Idempotency-Key:** sha256(pipeline_id, job_id, destination_dataset)
- **Ack/Nack:** 2xx or broker ACK; retry exp-backoff<=5x
- **Side-Effects:** annotate lineage in catalog; attach evidence to policy registry; update retention controls
- **HITL Token:** required when any parameter exceeds policy bounds or exception override granted
- **Observability:** trace_id, mission_id, policy_refs, decision_basis.*, classification_label, provenance.attestation
- **Retention/TTL:** 2 years or per privacy policy

Schema Capsule (OC-1) [Normative]

Requirement Level: Required

Condition: Always

schema_id=PETApplicationResult@1.0 | json_schema_uri=uri://schema/pet-application-result-1.0.json | sha256= | producers=F6 | consumers=Orchestrator-01, Catalog-01, SIEM-01 | accepts=1.0–1.x

Conformance: This capsule and the corresponding MCP schema define testable requirements.

OC-2: PrivacyException [Informative]

- **Producer(s):** F6
- **Topic/Path:** REST POST /privacy/exception, Kafka sec.privacy.exception
- **Schema/Format:** PrivacyException@1.0 { exception_id, pipeline_id, job_id, dataset, reason_code in {"no_lawful_basis","cross_border_violation","param_out_of_bounds","unsupporte

d_pet","policy_missing"}, details, evidence_refs[], required_action, approver_chain?, expires_at? }

- **Classification:** C2
- **Delivery:** at-least-once
- **Ordering:** per-pipeline_id
- **Idempotency-Key:** sha256(pipeline_id, job_id, reason_code)
- **Ack/Nack:** 2xx or broker ACK; retry/backoff; page owners on repeated NACK
- **Side-Effects:** open change/privacy review; block job in orchestrator; notify privacy officer
- **HITL Token:** required to authorize one-time override
- **Observability:** trace_id, mission_id, policy_refs, classification_label, provenance.attestation
- **Retention/TTL:** 1 year or legal_hold

Schema Capsule (OC-2) [Normative]

Requirement Level: Conditionally Required

Condition: When policy or constraints prevent PET application or processing
schema_id=PrivacyException@1.0 | json_schema_uri=uri://schema/privacy-exception-1.0.json | sha256= | producers=F6 | consumers=Change-01, Legal-01, Orchestrator-01 | accepts=1.0–1.x

Conformance: Normative when condition is met.

OC-3: PolicyDispute (Explainability and Contestability) [Informative, optional]

- **Producer(s):** F6; Privacy/Legal portals
- **Topic/Path:** sec.privacy.contestation
- **Schema/Format:** PolicyDispute@1.0 (pipeline_id, dataset, dispute_reason, business_justification, approver_chain, decision_rationale_url)

Schema Capsule (OC-3) [Normative]

Requirement Level: Optional

Condition: When contestability workflow is enabled

schema_id=PolicyDispute@1.0 | json_schema_uri=uri://schema/policy-dispute-1.0.json

OC-4: IRPolicyViolationEvent (Incident Response Integration) [Informative, optional]

- **Producer(s):** F6
- **Topic/Path:** sec.privacy.ir_event
- **Schema/Format:** IRPolicyViolationEvent@1.0 (unauthorized_transfer_attempt, epsilon_violation_attempt, k_breach_attempt)

Schema Capsule (OC-4) [Normative]

Requirement Level: Optional

Condition: When IR/SIEM integration is present

schema_id=IRPolicyViolationEvent@1.0 | json_schema_uri=uri://schema/ir-policy-violation-1.0.json

OC-5: ChangeImpactReport (Privacy Program Metrics) [Informative, optional]

- **Producer(s):** F6
- **Topic/Path:** sec.privacy.change_impact
- **Schema/Format:** ChangeImpactReport@1.0 (pipelines_enforced, fields_transformed_by_pet, average_epsilon, k_min_violations_prevented, cross_border_blocks, exception_hotspots)

Schema Capsule (OC-5) [Normative]

Requirement Level: Conditionally Required

Condition: When privacy program metrics and tuning are enabled

schema_id=ChangeImpactReport@1.0 | json_schema_uri=uri://schema/change-impact-1.0.json

OC-6: FeedbackIngestionEvent (Stakeholder Feedback Loop) [Informative, optional]

- **Producer(s):** Data owner portals; F6 (aggregation)
- **Topic/Path:** sec.privacy.feedback
- **Schema/Format:** FeedbackIngestionEvent@1.0 (labels={helpful|neutral|harmful}, artifact_refs, notes)

Schema Capsule (OC-6) [Normative]

Requirement Level: Optional

Condition: When reviewer feedback workflow is enabled

schema_id=FeedbackIngestionEvent@1.0 | json_schema_uri=uri://schema/feedback-ingestion-1.0.json

State machine (concise) [Informative]

states = { idle, analyzing_policy, selecting_pets, enforcing, summarizing, exception_open, contestation_workflow, failed, closed }

transition(idle -> analyzing_policy) on pipeline event or schedule

transition(analyzing_policy -> selecting_pets) when lawful basis and purpose verified

transition(selecting_pets -> enforcing) when parameters within bounds and region route allowed

transition(selecting_pets -> exception_open) when policy or constraints block processing

transition(enforcing -> summarizing) when transforms applied and validations pass

transition(any -> contestation_workflow) when PolicyDispute opened or override requested

transition(* -> failed) on schema or orchestrator error; NACK>5 or attestation invalid

timeout(enforcing, 300s) -> exception_open (reason=timeout_orchestrator)

idempotency_key = sha256(pipeline_id, job_id, destination_dataset)

Output Contracts Summary [Normative]

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-1 PETApplicationResult	Required	Always	Proof of PET enforcement and parameters
OC-2 PrivacyException	Conditionally Required	Policy/constraints prevent PET or processing	Governance and safety gate
OC-3 PolicyDispute	Optional	Contestability enabled	Arbitration and explainability
OC-4 IRPolicyViolationEvent	Optional	IR/SIEM integration present	Incident response integration

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-5 ChangeImpactReport	Conditionally Required	Program metrics and tuning enabled	Program risk and throughput management
OC-6 FeedbackIngestionEvent	Optional	Reviewer feedback workflow enabled	Continuous improvement

Requirement Level Definitions:

- **Required:** Must be implemented for conformant deployment
- **Conditionally Required:** Must be implemented when trigger condition is met
- **Optional:** May be implemented for enhanced functionality

Policies and HITL gates [Informative]

- **policy_refs:** GDPR Arts. 5/6/25; NIST IR 8062; ISO/IEC 27555; organization privacy policies; applicable overlays in NIST SP 800-53.
- **HITL required:** any override where epsilon would exceed `dp_epsilon_max`; `k` would drop below `k_min`; cross-border transfer when `no_cross_border_transfer:true`; CrownJewels datasets.
- **Automatic HITL escalation triggers:** `model_confidence < theta_low`; `reidentification_risk_score >= 0.5`; purpose ambiguity; repeated exceptions on the same pipeline.

SLOs and KPIs [Informative]

- `PETApplyLatency_p95 <= 60 s` per job
- `CrossBorderBlockAccuracy_30d >= 99.9` percent
- `ParamBoundViolationRate_7d <= 0.5` percent
- `ExceptionTimeToDecision_p95 <= 1` business day
- `ResidualRiskAboveTargetRate_30d <= 1` percent

Outputs index [Informative]

[OC-1 PETApplicationResult], [OC-2 PrivacyException], [OC-3 PolicyDispute], [OC-4 IRPolicyViolationEvent], [OC-5 ChangeImpactReport], [OC-6 FeedbackIngestionEvent]

Technical Implementation Details (F6) [Informative]

Model and training profile [Informative]

model_id=privacy-enforcement-text-model; temperature=0.1; max_tokens_out=600
prompt_pack_id=privacy-rubric-v1 (purpose-lawfulness matrix, PET selection rubric, cross-border rules)

RAG: sources={policy registry, pipeline catalog, data classification index, prior results and exceptions}; max_docs=12; min_similarity=0.78; citations required

fine_tuning/adapters: optional on synthetic PET decision logs; never on regulated content

guardrails: enforce dp_epsilon_max and k_min from constraints or policy defaults; require explicit purpose and lawful basis; deny cross-border when
no_cross_border_transfer:true

Memory and state [Informative]

working_memory.max_tokens=4k; eviction=recency_then_importance

episodic_memory: per mission_id journal (pipeline events, PET decisions, exceptions); ttl=365d

semantic_memory:

namespaces=["policies","pipelines","datasets","regions","exceptions"];

embeddings=text-embedding-sec-v1; k=8

durable_state_store: event-sourced journal; snapshot on pipeline release boundaries

consistency: at-least-once (results and exceptions)

idempotency: per Output Contracts

Decision and routing logic [Informative]

$$\text{privacy_risk_score} = 0.35\text{data_sensitivity} + 0.25\text{exposure_surface} + 0.2\text{reid_risk} + 0.2\text{purpose_ambiguity}$$

where

data_sensitivity in {0.2 general, 0.6 pii, 1.0 sensitive_pii}

exposure_surface in {0.2 internal, 0.6 partner, 1.0 public_cloud_external_share}

reid_risk estimated via k_estimate and quasi_identifier_count

purpose_ambiguity = 1.0 if purpose missing else 0.0

Parameter selection:

- $\text{epsilon} = \min(\text{dp_epsilon_max}, \text{base_epsilon} * \text{risk_factor})$
where $\text{base_epsilon} = 0.5$ and $\text{risk_factor} = 1.0 + 0.5 * \text{privacy_risk_score}$
- $k = \max(k_min, k_baseline - \text{round}(5 * (1 - \text{privacy_risk_score})))$ with $k_baseline = 15$

- $\text{generalization_level} = \text{ceil}(2 * \text{privacy_risk_score})$
Routing:
- if $\text{cross_border_violation}=\text{true}$ or $\text{lawful_basis_missing}=\text{true}$ -> emit `PrivacyException` and block
- else apply PETs and emit `PETApplicationResult`; require HITL token for overrides beyond bounds

Model Risk Management [Informative]

`continuous_validation`: daily goldens plus adversarial test cases (linkage attacks, geography routing edge cases)

`thresholds`: `eval_pass_rate` ≥ 99.5 percent $\rightarrow$ else `auto_HITL`

`red_team_cycle`: monthly re-identification simulations and cross-border evasion attempts

`rollback_policy`: `eval_drop` ≥ 1.5 percentage points for 48 h $\rightarrow$ revert

`model/prompt_pack`; notify owners

Transparency and Audit Trail (Approver/Auditor UX) [Informative]

`decision_rationale_template`: purpose, lawful basis, chosen PET per field, parameters, `evidence_refs`, cross-border check result, retention settings

UI/API: expose `classification_label`, `provenance.attestation`, `decision_rationale_url`

`audit_log_format`: JSONL with stable field order; retention per policy and `legal_hold`

Incident Response Integration [Informative]

emit `IRPolicyViolationEvent` (OC-4) on unauthorized transfer attempts or parameter violation attempts; attach pipeline id, dataset, policy rule refs

Change Impact Assessment [Informative]

emit `ChangeImpactReport` (OC-5) aggregating transforms, parameter distributions, and exception hotspots; inform rubric tuning

Stakeholder Feedback Loop [Informative]

emit `FeedbackIngestionEvent` (OC-6) from owner portals; use labels to tune defaults after governance review; never auto-train on regulated content

Data Sovereignty and Legal Hold [Informative]

enforce region routes; block when `legal_hold=true` unless explicit legal directive provided; override requires HITL token and auditable trail

Interfaces (links only) [Informative]

Consumes: Data Pipeline Manifests; Privacy Policies

Produces: OC-1, OC-2 (+ optional OC-3..OC-6)

Safety and abuse prevention [Informative]

kill_switch on unexpected cross-border flow spikes; cost/QPS limits; sandbox mode for new engines; blast-radius caps for parameter overrides per day

Testing and validation [Informative]

contract tests for OC-1/OC-2; offline replay of pipeline runs; synthetic cross-border and parameter-bound violations; drift checks and rollback

Deployment and lifecycle [Informative]

scale with job volume; backpressure on orchestrator APIs; canary by pipeline group; SBOM and attestations; sign all outputs

References / Standards [Informative]

NIST SP 800-160 Vol. 2; NIST IR 8062; NIST SP 800-53 Rev. 5 (AP, AR, DM, IP overlays); ISO/IEC 27555; GDPR (Arts. 5, 6, 25, 32); NIST CSF 2.0; ISO/IEC 27002:2022; CIS Controls v8

MCP-Native Protocol Specification (F6) [Normative]

- **Native Protocol(s) Consumed:** Data Pipeline Manifests (Airflow/dbt/Spark/Kafka/Beam); Privacy Policies (Policy Registry/OPA/Legal Catalog)
- **Native Protocol(s) Produced:** **PETApplicationResult** (REST/Kafka); **PrivacyException** (REST/Kafka, optional)
- **MCP Context Fields:**
 - **Required:** mission_id; role="PrivacyEnforcementAgent"; intent="enforce"; jurisdiction; legal_basis; purpose; data_subject_region; policy_refs; provenance (SPIFFE ID, signing KID, attestation)
 - **Optional:** classification; constraints; decision_basis; legal_hold
- **Enforcement Note:** Orchestrators must verify provenance.attestation, region routing compliance, and parameter bounds (epsilon and k) before executing writes; blocks must be honored when PrivacyException is emitted.

- **Versioning and compatibility; producers/consumers registry:** authoritative in schema registry; see Schema Capsules for accepted ranges/EOL dates.
- **Example payloads:** authoritative native and MCP-wrapped examples as provided above.
- **Transparency hooks:** `classification_label`, `provenance.attestation`, `decision_rationale_url` exposed to downstream UIs/APIs.

Conformance: This section is **[Normative]** and, together with each **Schema Capsule**, defines testable requirements.